



## **Cyber Security (CYBER); CRA; Cybersecurity requirements for smart home general purpose virtual assistants**

Exercising one of the Principles of international standardization - Openness - and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

### **Disclaimer**

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

### **Commenting guidelines**

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

### **How to comment**

To comment or provide feedback on the present interim draft please visit: [STAN4CRA / EN 304 631 Smart home assistants - GitLab](#) and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: [cybersupport@etsi.org](mailto:cybersupport@etsi.org) using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

---

**Reference**

---

DEN/CYBER-EUS-0011

---

**Keywords**

---

CRA, Cybersecurity, intelligent homes & buildings

0

**ETSI**

---

650 Route des Lucioles  
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B  
Association à but non lucratif enregistrée à la  
Sous-Préfecture de Grasse (06) N° w061004871

---

**Important notice**

The present document can be downloaded from the  
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,  
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to  
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our  
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

---

**Notice of disclaimer & limitation of liability**

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

---

**Copyright Notification**

---

Reproduction is only permitted for the purpose of standardization work undertaken within ETSI.  
The copyright and the foregoing restrictions extend to reproduction in all media.

© ETSI 2026.  
All rights reserved.

# Contents

|    |                                                                                                         |    |
|----|---------------------------------------------------------------------------------------------------------|----|
| 1  | Intellectual Property Rights.....                                                                       | 7  |
| 2  | Foreword.....                                                                                           | 7  |
| 3  | Modal verbs terminology .....                                                                           | 8  |
| 4  | 1 Scope.....                                                                                            | 9  |
| 5  | 2 References.....                                                                                       | 9  |
| 6  | 2.1 Normative references.....                                                                           | 9  |
| 7  | 2.2 Informative references.....                                                                         | 9  |
| 8  | 3 Definition of terms, symbols and abbreviations.....                                                   | 10 |
| 9  | 3.1 Terms.....                                                                                          | 10 |
| 10 | 3.2 Abbreviations.....                                                                                  | 14 |
| 11 | 4 Product context.....                                                                                  | 14 |
| 12 | 4.1 Product functions.....                                                                              | 14 |
| 13 | 4.2 Product Architecture.....                                                                           | 15 |
| 14 | 4.3 Operational Environment.....                                                                        | 16 |
| 15 | 4.4 Interface.....                                                                                      | 17 |
| 16 | 4.5 Distribution of security functions .....                                                            | 17 |
| 17 | 4.6 Users.....                                                                                          | 17 |
| 18 | 4.7 Use cases.....                                                                                      | 18 |
| 19 | 4.7.1 General.....                                                                                      | 18 |
| 20 | 4.7.2 Use case profiles .....                                                                           | 18 |
| 21 | 4.8 Security Profiles.....                                                                              | 18 |
| 22 | 5 Requirements specifications.....                                                                      | 19 |
| 23 | 5.1 Product's technical requirements specifications.....                                                | 19 |
| 24 | 5.1.1 Known exploitable vulnerabilities.....                                                            | 19 |
| 25 | 5.1.1.1 [NKEV-MKAV] No known exploitable vulnerabilities.....                                           | 19 |
| 26 | 5.1.1.2 [NKEV-SUM-SUPPORT] Secure software update mechanism.....                                        | 20 |
| 27 | 5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components .....                   | 20 |
| 28 | 5.1.1.4 [NKEV-SUM-AUTO] Automated security updates.....                                                 | 20 |
| 29 | 5.1.1.5 [NKEV-SUM-NOTIF] Update notifications .....                                                     | 20 |
| 30 | 5.1.2 Default configuration .....                                                                       | 20 |
| 31 | 5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm ... | 20 |
| 32 | 5.1.2.2 [SDC-SUM-AUTO] Default configuration of automated security updates.....                         | 20 |
| 33 | 5.1.2.3 [SDC-SUM-NOTIF] Default configuration of update notifications.....                              | 20 |
| 34 | 5.1.2.4 [SDC-FRM] Factory reset to restore the default state .....                                      | 21 |
| 35 | 5.1.3 Authentication and access control mechanisms .....                                                | 21 |
| 36 | 5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm.....                             | 21 |
| 37 | 5.1.3.2 [AUM-FH] Authentication for functions whose use can cause harm.....                             | 21 |
| 38 | 5.1.3.3 [AUTHZ-LP] Least privilege in authorization policies.....                                       | 22 |
| 39 | 5.1.3.4 [AUTHZ-R] Revocability of granted permissions .....                                             | 22 |
| 40 | 5.1.4 Integrity protection.....                                                                         | 22 |
| 41 | 5.1.4.1 [INT-SWPCCK] Software package verification .....                                                | 22 |
| 42 | 5.1.4.2 [INT-COM] Communication of integrity relevant data.....                                         | 23 |
| 43 | 5.1.5 Confidentiality protection .....                                                                  | 23 |
| 44 | 5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data .....            | 23 |
| 45 | 5.1.5.2 [CONF-COM] Communication of confidential data.....                                              | 23 |
| 46 | 5.1.6 Data minimization .....                                                                           | 24 |
| 47 | 5.1.6.1 [DMIN-DJST] Documented justification of processed data.....                                     | 24 |
| 48 | 5.1.7 Availability protection.....                                                                      | 24 |
| 49 | 5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power .....                                      | 24 |
| 50 | 5.1.7.2 [AVAI-TIME-NETW] Local operation.....                                                           | 24 |
| 51 | 5.1.7.3 [AVAI-TIME-RECO-NETW] Restoration after loss of network connection .....                        | 24 |
| 52 | 5.1.7.4 [AVAI-TIME-OUTA-NOT] Notify non-availability .....                                              | 24 |
| 53 | 5.1.7.5 [AVAI-TIME-PREV-NOT] Notify upcoming limitation.....                                            | 24 |
| 54 | 5.1.7.6 [AVAI-TIME-NET-PRIO] Network prioritization .....                                               | 25 |
| 55 |                                                                                                         |    |

|     |                               |                                                                                                |           |
|-----|-------------------------------|------------------------------------------------------------------------------------------------|-----------|
| 56  | 5.1.7.7                       | [AVAI-TIME-RES-PRIO] Resource prioritization .....                                             | 25        |
| 57  | 5.1.7.8                       | [AVAI-TIME-IMP-AMP] Amplification control .....                                                | 25        |
| 58  | 5.1.7.9                       | [AVAI-TIME-DOS-RATE] Incoming rate limiting .....                                              | 25        |
| 59  | 5.1.7.10                      | [AVAI-SUM-SCHEDULE] Scheduling of updates .....                                                | 25        |
| 60  | 5.1.8                         | Impact minimization .....                                                                      | 25        |
| 61  | 5.1.9                         | Limit attack surface .....                                                                     | 25        |
| 62  | 5.1.9.1                       | [LAS-INVAL] Validation of external data input .....                                            | 25        |
| 63  | 5.1.9.2                       | [LAS-INSAN] Sanitization of external data input .....                                          | 26        |
| 64  | 5.1.9.3                       | [LAS-PHY-INF] Only necessary physical interfaces .....                                         | 26        |
| 65  | 5.1.9.4                       | [LAS-LOGIC-INF] Only necessary logical interfaces active by default .....                      | 26        |
| 66  | 5.1.9.5                       | [LAS-APP] Only necessary apps by default .....                                                 | 26        |
| 67  | 5.1.9.6                       | [LAS-SBOOT] Secure boot .....                                                                  | 26        |
| 68  | 5.1.10                        | Logging and monitoring mechanisms .....                                                        | 26        |
| 69  | 5.1.10.1                      | [LOG-LOW] Events to log for low risk SHGPVA .....                                              | 26        |
| 70  | 5.1.10.2                      | [LOG-MEDIUM] Events to log for medium risk SHGPVA .....                                        | 26        |
| 71  | 5.1.10.3                      | [LOG-HIGH] Events to log for high risk SHGPVA .....                                            | 27        |
| 72  | 5.1.10.4                      | [LOG-TIME] Timestamps for logs .....                                                           | 27        |
| 73  | 5.1.10.5                      | [LOG-TIME-HIGH] Real-Timestamps for logs .....                                                 | 27        |
| 74  | 5.1.10.6                      | [LOG-STORAGE] Persistently store logfiles .....                                                | 27        |
| 75  | 5.1.10.7                      | [LOG-BACKUP] Backup of logfiles .....                                                          | 27        |
| 76  | 5.1.11                        | Deletion mechanisms .....                                                                      | 27        |
| 77  | 5.1.12                        | Other product's technical requirements specifications .....                                    | 27        |
| 78  | 5.1.12.1                      | [USERNOT-NOSECFUC] User notifications on not available security functions .....                | 27        |
| 79  | 5.2                           | Requirements specifications for vulnerability handling activities related to the product ..... | 28        |
| 80  | 6                             | Assessing for compliance with requirements .....                                               | 28        |
| 81  | 6.1                           | Assessing for compliance with product's technical requirements specifications .....            | 28        |
| 82  | 6.1.1                         | General .....                                                                                  | 28        |
| 83  | 6.1.2                         | Known exploitable vulnerabilities .....                                                        | 28        |
| 84  | 6.1.2.1                       | Assessment criteria for [NKEV-MKAV] .....                                                      | 28        |
| 85  | 6.1.3                         | Default configuration .....                                                                    | 28        |
| 86  | 6.1.3.1                       | Assessment criteria for [SDC-FRM] .....                                                        | 28        |
| 87  | 6.1.4                         | Authentication and access control mechanisms .....                                             | 29        |
| 88  | 6.1.4.1                       | Assessment criteria for [ACM-FH] .....                                                         | 29        |
| 89  | 6.1.4.2                       | Assessment criteria for [AUM-FH] .....                                                         | 30        |
| 90  | 6.1.4.3                       | Assessment criteria for [AUTHZ-LP] .....                                                       | 31        |
| 91  | 6.1.4.4                       | Assessment criteria for [AUTHZ-R] .....                                                        | 32        |
| 92  | 6.1.5                         | Integrity protection .....                                                                     | 33        |
| 93  | 6.1.6                         | Confidentiality protection .....                                                               | 33        |
| 94  | 6.1.7                         | Data minimization .....                                                                        | 33        |
| 95  | 6.1.7.1                       | Assessment criteria for [DMIN-DJST] .....                                                      | 33        |
| 96  | 6.1.8                         | Availability protection .....                                                                  | 34        |
| 97  | 6.1.8.1                       | Assessment criteria for [AVAI-TIME-RECO-POW] .....                                             | 34        |
| 98  | 6.1.8.2                       | Assessment criteria for [AVAI-TIME-NETW] .....                                                 | 36        |
| 99  | 6.1.9                         | Impact minimization .....                                                                      | 37        |
| 100 | 6.1.10                        | Limit attack surface .....                                                                     | 37        |
| 101 | 6.1.10.1                      | Assessment criteria for [LAS-SBOOT] .....                                                      | 37        |
| 102 | 6.1.11                        | Logging and monitoring mechanisms .....                                                        | 38        |
| 103 | 6.1.12                        | Deletion mechanisms .....                                                                      | 38        |
| 104 | 6.1.13                        | Other product's technical requirements specifications .....                                    | 38        |
| 105 | 6.2                           | Assessment criteria for vulnerability handling activities related to the product .....         | 38        |
| 106 | <b>Annex A (informative):</b> | <b>Relationship between the present document and the requirements of</b>                       |           |
| 107 |                               | <b>EU Regulation 2024/2847 .....</b>                                                           | <b>39</b> |
| 108 | <b>Annex B (informative):</b> | <b>Guidance for the application of the present document .....</b>                              | <b>45</b> |
| 109 | <b>Annex C (informative):</b> | <b>Information on the methodology for the assessment of cybersecurity</b>                      |           |
| 110 |                               | <b>risks used to develop the present document .....</b>                                        | <b>48</b> |
| 111 | C.1                           | Guidance for determining impact classes .....                                                  | 48        |
| 112 | C.1.1                         | General .....                                                                                  | 48        |
| 113 | C.1.2                         | confidential data .....                                                                        | 48        |

|     |                             |                                                                                                      |           |
|-----|-----------------------------|------------------------------------------------------------------------------------------------------|-----------|
| 114 | C.1.3                       | loss sensitive data .....                                                                            | 48        |
| 115 | C.1.4                       | time sensitive data and time sensitive function.....                                                 | 49        |
| 116 | C.1.5                       | integrity relevant data and integrity relevant function .....                                        | 49        |
| 117 | <b>Annex D (normative):</b> | <b>Relationship between specific data and functions assets covered by</b>                            |           |
| 118 |                             | <b>the present document to impact classes for generic asset categories .....</b>                     | <b>50</b> |
| 119 | D.1                         | Identifier.....                                                                                      | 50        |
| 120 | D.2                         | Data assets .....                                                                                    | 52        |
| 121 | D.3                         | Function assets .....                                                                                | 52        |
| 122 | D.3.1                       | functions whose use can cause harm.....                                                              | 53        |
| 123 | <b>Annex E (normative):</b> | <b>Protection measures.....</b>                                                                      | <b>54</b> |
| 124 | E.1                         | Identifier.....                                                                                      | 54        |
| 125 | E.2                         | access control mechanism's strength.....                                                             | 55        |
| 126 | E.3                         | authentication mechanism strength .....                                                              | 55        |
| 127 | E.3.1                       | AUM-FH Authentication for functions whose use can cause harm.....                                    | 55        |
| 128 | E.3.1.1                     | General .....                                                                                        | 55        |
| 129 | E.3.1.2                     | authentication strength level basic .....                                                            | 55        |
| 130 | E.3.1.3                     | authentication strength level normal .....                                                           | 55        |
| 131 | E.3.1.4                     | authentication strength level enhanced.....                                                          | 55        |
| 132 | E.3.1.5                     | authentication strength level strong.....                                                            | 56        |
| 133 | E.3.2                       | Assessment for authentication mechanism strength .....                                               | 56        |
| 134 | E.3.2.1                     | Assessment criteria regarding the protection against limited presentation attacks.....               | 56        |
| 135 | E.3.2.2                     | Assessment criteria regarding the protection against targeted presentation attacks .....             | 57        |
| 136 | E.3.2.3                     | Assessment criteria regarding the protection against elaborate presentation attacks .....            | 57        |
| 137 | E.3.2.4                     | Assessment criteria regarding the protection against limited brute force attacks.....                | 58        |
| 138 | E.3.2.5                     | Assessment criteria regarding the protection against targeted brute force attacks .....              | 59        |
| 139 | E.3.2.6                     | Assessment criteria regarding the protection against automated brute force attacks .....             | 59        |
| 140 | E.3.2.7                     | Assessment criteria regarding the protection against presentation attacks.....                       | 60        |
| 141 | E.3.2.8                     | Assessment criteria regarding the protection against elaborate brute force attacks .....             | 61        |
| 142 | E.3.2.9                     | Assessment criteria regarding the protection against automated security token spoofing attacks ..... | 61        |
| 143 | E.3.2.10                    | Assessment criteria regarding the protection against targeted security token spoofing attacks .....  | 62        |
| 144 | E.3.2.11                    | Assessment criteria regarding the protection against elaborate security token spoofing attacks ..... | 62        |
| 145 | E.3.2.12                    | Assessment criteria regarding the protection against replay attacks .....                            | 63        |
| 146 | E.3.2.13                    | Assessment criteria regarding the protection against PitM attacks .....                              | 64        |
| 147 | E.4                         | confidentiality protection strength.....                                                             | 65        |
| 148 | E.4.1                       | CONF-SSM Confidentiality protecting persistent storage for confidential data .....                   | 65        |
| 149 | E.4.1.1                     | General .....                                                                                        | 65        |
| 150 | E.4.1.2                     | confidential persistent storage strength level basic .....                                           | 65        |
| 151 | E.4.1.3                     | confidential persistent storage strength level normal .....                                          | 65        |
| 152 | E.4.1.4                     | confidential persistent storage strength level enhanced .....                                        | 65        |
| 153 | E.4.1.5                     | confidential persistent storage strength level strong.....                                           | 65        |
| 154 | E.5                         | confidentiality protection strength.....                                                             | 65        |
| 155 | E.5.1                       | CONF-COM Communication of confidential data.....                                                     | 65        |
| 156 | E.5.1.1                     | General .....                                                                                        | 65        |
| 157 | E.5.1.2                     | communication of confidential data protection strength level basic .....                             | 65        |
| 158 | E.5.1.3                     | communication of confidential data protection strength level normal .....                            | 66        |
| 159 | E.5.1.4                     | communication of confidential data protection strength level enhanced.....                           | 66        |
| 160 | E.5.1.5                     | communication of confidential data protect ion strength level strong.....                            | 66        |
| 161 | E.6                         | integrity protection strength .....                                                                  | 66        |
| 162 | E.6.1                       | INT-SWPCK Software package verification.....                                                         | 66        |
| 163 | E.6.1.1                     | General .....                                                                                        | 66        |
| 164 | E.6.1.2                     | software package integrity verification strength level basic.....                                    | 67        |
| 165 | E.6.1.3                     | software package integrity verification strength level normal .....                                  | 67        |
| 166 | E.6.1.4                     | software package integrity verification strength level enhanced.....                                 | 67        |
| 167 | E.6.2                       | INT-COM Communication of integrity relevant data .....                                               | 67        |

|     |                               |                                                                                   |           |
|-----|-------------------------------|-----------------------------------------------------------------------------------|-----------|
| 168 | E.6.2.1                       | General .....                                                                     | 67        |
| 169 | E.6.2.2                       | communication of integrity relevant data protection strength level basic .....    | 67        |
| 170 | E.6.2.3                       | communication of integrity relevant data protection strength level normal .....   | 67        |
| 171 | E.6.2.4                       | communication of integrity relevant data protection strength level enhanced ..... | 67        |
| 172 | E.6.2.5                       | communication of integrity relevant data protection strength level strong .....   | 68        |
| 173 | <b>Annex F (informative):</b> | <b>Relationship between the present document and the covered/not</b>              |           |
| 174 |                               | <b>covered cybersecurity risks.....</b>                                           | <b>69</b> |
| 175 | <b>Annex G (informative):</b> | <b>Relationship between the present document and ETSI EN 303 645/</b>             |           |
| 176 |                               | <b>ETSI TS 103 701 .....</b>                                                      | <b>73</b> |
| 177 | History .....                 |                                                                                   | 74        |
| 178 |                               |                                                                                   |           |
| 179 |                               |                                                                                   |           |

## Intellectual Property Rights

### Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

### Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

**DECT™**, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

## Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

| Proposed national transposition dates                                                  |                                 |
|----------------------------------------------------------------------------------------|---------------------------------|
| Date of latest announcement of this EN (doa):                                          | 3 months after ETSI publication |
| Date of latest publication of new National Standard or endorsement of this EN (dop/e): | 6 months after doa              |
| Date of withdrawal of any conflicting National Standard (dow):                         | 18 months after doa             |

---

## Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.



# 1 Scope

The present document specifies vulnerability handling activities, technical characteristics and corresponding assessment criteria for smart home general purpose virtual assistants related to cybersecurity. Smart home general purpose virtual assistants

- are specified within the "technical description" of the "category of product" number "16." by Regulation (EU) 2025/2392 [i.2] and
- are only covered within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] under the conditions identified in annex A.

## 2 References

### 2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- |     |                                                                                                                                                                                       |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [1] | CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3): "Cybersecurity requirements for products with digital elements - Vulnerability Handling".                                             |
| [2] | Agreed Cryptographic Mechanisms: "European Union Agency for Cybersecurity, European Cybersecurity Certification Group - Sub-group on Cryptography - Agreed Cryptographic Mechanisms". |

### 2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

- |       |                                                                                                                                                                                                                                                                                                                                        |
|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [i.1] | <a href="#">Regulation (EU) 2024/2847</a> : "Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)". |
| [i.2] | <a href="#">Regulation (EU) 2025/2392</a> : "Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council".                       |

- 263 [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on  
 264 a standardisation request to the European Committee for Standardisation (CEN), the European  
 265 Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications  
 266 Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU)  
 267 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal  
 268 cybersecurity requirements for products with digital elements and amending Regulations (EU) No  
 269 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".
- 270 [i.4] CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1): "Cybersecurity requirements for  
 271 products with digital elements – Vocabulary".
- 272 [i.5] ETSI EN 304 623 V1.1.1: "Cyber Security (CYBER); CRA; Cybersecurity requirements for boot  
 273 managers".

---

## 274 3 Definition of terms, symbols and abbreviations

### 275 3.1 Terms

276 For the purposes of the present document, the terms and definitions given in Regulation (EU) 2024/2847 [i.1],  
 277 CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1) [i.4] and the following apply:

#### 278 ARCHITECTURE RELATED TERMS

279 **application software**: software designed to perform specific consumer- or SHGPVA-oriented functional tasks on a  
 280 device, operating on top of the core software, and without direct responsibility for hardware initialization or  
 281 fundamental system control

282 **EXAMPLE:** A mobile app, desktop software or parts of MP's embedded software that implements essential  
 283 functionalities.

284 **NOTE:** Application software typically uses APIs provided by core software.

285 **core software**: Any software that abstracts hardware, manages hardware resources and provides interfaces for other  
 286 software to interact with each other or the core software

287 **EXAMPLE:** a physical MP's operating system, hardware abstraction layer or APIs for application software.

288 **main product**: SHGPVA excluding its RDPS

#### 289 GENERAL DATA RELATED TERMS

290 **data**: information in digital form

291 **location data**: data containing geographical information

292 **public data**: data from publicly accessible sources

293 **user data**: data provided by a consumer

#### 294 VERTICAL SPECIFIC DATA RELATED TERMS

295 **void**: void

#### 296 GENERAL FUNCTIONALITY RELATED TERMS

297 **authorization policy**: policy that describes the access rights of entities on SHGPVA's data and functions

298 **function trigger input**: input to the RDPSs' or MP's functions provided by:

- 299 • human users,
- 300 • devices or services, or

- the physical operational environment

**function output:** output of RDPSs' or MP's functions that is:

- a modification or creation of SHGPVAs' data or functions
- information intended to inform human users
- information intended to inform or control devices or services, or
- an action on the physical operational environment

## VERTICAL SPECIFIC FUNCTIONALITY RELATED TERMS

**virtual assistant function:** SHGPVA function which provides function output as reaction to function trigger input related to assistance of a consumer and can process natural language prompts

## GENERAL DATA ASSETS

**audio input data:** data asset that represents audio information captured by the SHGPVA

**authorization policy data:** data asset that contains an authorization policy

EXAMPLE: assignment of privileges to consumers.

**network status data:** data asset that describes MPs' or RDPSs' network connections status

**SHGPVA state data:** data asset that contains SHGPVA state information

**software package:** data asset that contains software intended to be installed on the SHGPVA

**video input data:** data asset that represents video information captured by the SHGPVA

EXAMPLE: Video or picture recordings processed (including storage) on the SHGPVA.

## VERTICAL SPECIFIC DATA ASSETS

**activity data:** data asset that describes physical movements, behaviors or activity patterns to monitor the personal fitness level of humans

**device location data:** data asset containing information on the geographical information of devices

**health data:** data asset that indicates information about physiological functions, health condition or physical fitness of humans

**personal calendar data:** data asset that represents information on a personal calendar

**personal contact data:** data asset that represents personal contact information of entities

**public data asset:** data asset derived from public data

**personal notes data:** data asset that represents information on a personal notes

## GENERAL FUNCTION ASSETS

**audio input function:** SHGPVA function that converts audio signals into data

**audio output function:** SHGPVA function that converts data into audio signals

**access control mechanism:** SHGPVA function that enforces an authorization policy

**authentication mechanism:** SHGPVA function that verifies an entity's claim

**bootloader function:** SHGPVA function that initiates the execution of other core software at startup.

**configuration function:** SHGPVA function that allows to change the configuration of SHGPVA's functions

336 **connection function:** SHGPVA function that is used for testing or establishing communication capability via machine  
337 interface

338 **EXAMPLE:** ICMP, DHCP Discovery.

339 **NOTE:** In this context, establishing communication means communication without user data and without  
340 authentication of the communication partner for the purpose of establishment of a connection.

341 **factory reset function:** SHGPVA function that removes all user data and sets the MP in a factory default state,  
342 potentially keeping software updates

343 **input sanitization mechanism:** SHGPVA function that scans function input data and removes or alters parts, that can  
344 lead to incidents based on a function specific pattern

345 **input validation mechanism:** SHGPVA function that rejects input data if it does not meet an accepted pattern

346 **logging mechanism:** SHGPVA function that logs events

347 **notification mechanism:** SHGPVA function that notifies entities on certain events

348 **real-time service or clock:** service or function that provides real time information

349 **software package verification mechanism:** SHGPVA function that verifies the integrity and authenticity of software  
350 packages

351 **software update mechanism:** SHGPVA function that allows to change the SHGPVA's software

352 **time service or function:** service or function that provides time information

353 **video input function:** SHGPVA function that converts video signals into data

354 **video output function:** SHGPVA function that converts data into video signals

## 355 VERTICAL SPECIFIC FUNCTION ASSETS

### 356 INTERFACES

357 **human interface:** interface that is intended to be used by human

358 **interface:** shared boundary across which the SHGPVA exchanges information

359 **logical human interface:** interface that is a human interface and a logical interface

360 **logical interface:** interface that does not exist in hardware and can only be used by using another device or a physical  
361 interface of a product with digital elements

362 **machine interface:** interface that is intended to be used for machine-to-machine communication

363 **physical human interface:** interface that is a human interface and a physical interface

364 **physical interface:** interface that is part of the hardware of a SHGPVA

### 365 COMMUNICATION TYPES

366 **adjacent communication:** public communication limited to a logically adjacent topology or ingoing/outgoing  
367 communication to private networks

368 **local communication:** ingoing/outgoing communication which requires physical access to a communication partner's  
369 interface or proximity of the communication partner to the product

370 **physical communication:** communication that requires physical interchange with the communication partner's  
371 hardware or the hardware the communication partner runs on

372 **public communication:** ingoing/outgoing communication to public networks

373 **strict local communication:** ingoing/outgoing communication which requires physical presence at a communication  
374 partner's interface

## OPERATIONAL ENVIRONMENTS

**confined operational environment:** physical operational environment, where the geographical location is confined to a specific area

**fully controlled physical operational environment:** physical operational environment, where physical access is fully controlled by the consumer or trusted persons

EXAMPLE: private house or apartment.

**logical operational environment:** operational environment describing the accessibility via logical interfaces

**mobile operational environment:** physical operational environment, where the geographical location is changing during operation and not confined to a specific area

NOTE: Physical operational environment of smartphones and wearables.

**partially controlled physical operational environment:** physical operational environment, that is not a fully controlled physical operational environment and either under the control of a limited set of persons or located in an area where untrusted physical access is suspicious

EXAMPLE: shared area in a house with different apartments or private property where public access is not intended.

**physical operational environment:** operational environment determining the physical accessibility of an architectural component

**stationary operational environment:** physical operational environment, where the geographical location is fixed

**uncontrolled physical operational environment:** physical operational environment, where physical access control on arbitrary untrusted entities cannot be ensured for prolonged time periods and where untrusted physical access is not necessarily suspicious

EXAMPLE: Areas intended for public access.

## GENERIC ASSET CATEGORIES

**confidential data:** data asset, whose disclosure can have a negative impact

**data asset:** asset, that is data processed by the SHGPVA

**function asset:** asset, that is a function of the SHGPVA

**function, whose use can cause harm:** function asset that is:

- a function, whose use can impact the availability of other devices, services or networks,
- a function, whose use can impact the safety or privacy of human entities,
- a function, which can communicate confidential data,
- a function, which can communicate integrity relevant data,
- a function, which can modify integrity relevant data, or
- a function, which can modify integrity relevant functions

**integrity relevant data:** data asset, whose tampering can have a negative impact

**integrity relevant function:** function asset, whose tampering can have a negative impact

**loss sensitive data:** data asset, whose permanent loss has a negative impact

**time sensitive data:** data asset, where a time delay in availability has a negative impact

**time sensitive function:** function asset, where a time delay in availability has a negative impact

## USERS

414 **consumer:** natural entity that directly interacts with the SHGPVA

## 415 3.2 Abbreviations

416 For the purposes of the present document, the following abbreviations apply:

|     |        |                                              |
|-----|--------|----------------------------------------------|
| 417 | DHCP   | Dynamic Host Configuration Protocol          |
| 418 | GUI:   | Graphical User Interface                     |
| 419 | ICMP   | Internet Control Message Protocol            |
| 420 | MP     | Main Product                                 |
| 421 | RDPS   | Remote Data Processing Solution              |
| 422 | SHGPVA | Smart Home General Purpose Virtual Assistant |
| 423 | VAF    | Virtual Assistant Function                   |

---

## 424 4 Product context

### 425 4.1 Product functions

426 The present document addresses the following essential functionalities of SHGPVA:

- 427 • **VAFs** that might make use of the following functions:
- 428 - audio input function
  - 429 - video input function
  - 430 - audio output function
  - 431 - video output function
  - 432 - SHGPVA function which can communicate SHGPVA data
  - 433 - SHGPVA function which can modify SHGPVA data

434 The present document addresses the following supporting functionalities of SHGPVA:

- 435 • configuration function
- 436 • software update mechanism
- 437 • monitoring mechanism
- 438 • notification mechanism
- 439 • logging mechanism
- 440 • access control mechanism
- 441 • authentication mechanism
- 442 • factory reset function
- 443 • integrity protecting communication mechanism
- 444 • confidentiality protecting communication mechanism
- 445 • integrity protecting secure storage mechanism
- 446 • confidentiality protecting secure storage mechanism
- 447 • deletion mechanism

- 448       •     onboarding mechanism
- 449       •     input sanitization mechanism
- 450       •     input validation mechanism
- 451       •     software package verification mechanism
- 452       •     bootloader function
- 453       •     time service or function
- 454       •     real-time service or clock

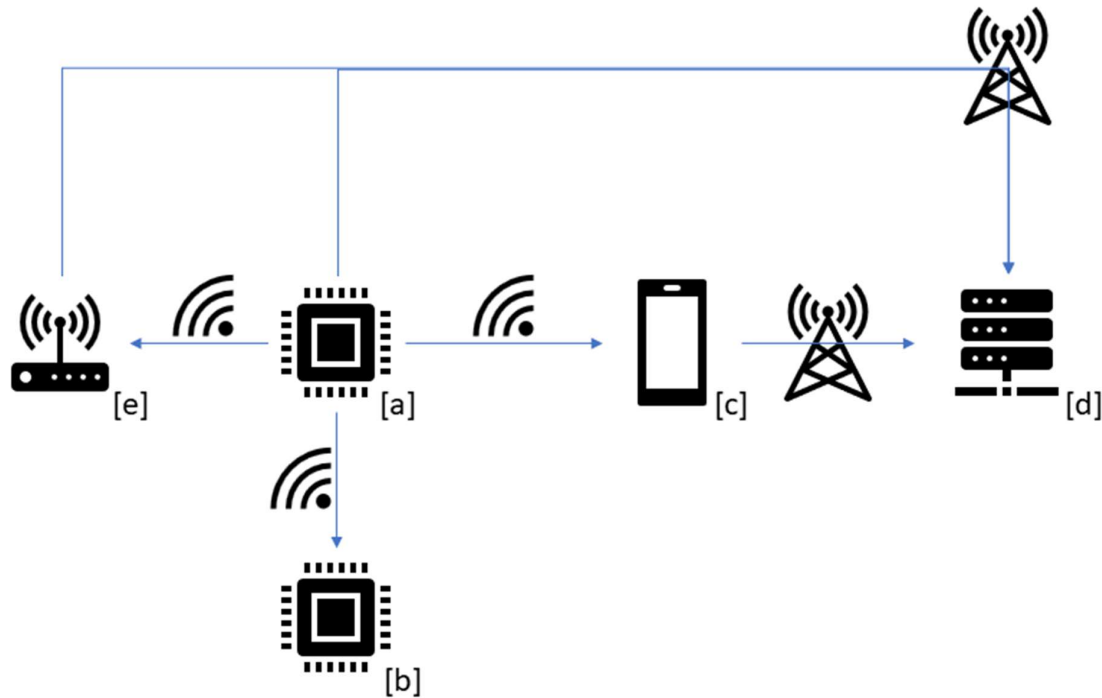
455     The essential and supporting functionalities might process the following data assets:

- 456       •     audio input data
- 457       •     video input data
- 458       •     network status data
- 459       •     authorization policy data
- 460       •     SHGPVA state data
- 461       •     logging data
- 462       •     software package
- 463       •     public data asset
- 464       •     personal calendar data
- 465       •     personal notes data
- 466       •     personal contact data
- 467       •     health data
- 468       •     activity data
- 469       •     device location data.

## 470     4.2     Product Architecture

471     The architecture of a SHGPVA consists of the following architectural components:

- 472       •     Software MP or Hardware MP including software
- 473       •     (optional) App RDPS
- 474       •     (optional) Cloud RDPS



**Figure 1: Architectural Components and possible connections between them**

Exemplary architectural components and possible connections between them are shown in figure 1. The following components are shown in the figure:

- a) MP
- b) Another SHGPVA's MP
- c) App RDPS
- d) Cloud RDPS
- e) A gateway.

NOTE: Not all subsets of connected components necessarily correspond to the scope of the present document (see clause 1).

## 4.3 Operational Environment

The present document addresses the following operational environments of SHGPVA.

For the logical operational environment, the following digital communication types are addressed for any architectural component of the SHGPVA:

- **public communication** - COM.Public
- **adjacent communication** - COM.Adjacent
- **local communication** - COM.Local
- **strict local communication** - COM.StrictLocal.

For the physical operational environment, the following environments are addressed for MPs:

- **fully controlled physical operational environment** - POE.FullyControlled



- **partially controlled physical operational environment** - POE.PartiallyControlled
- **mobile operational environment** - POE.Mobile.

For the physical operational environment, the following environments are addressed for App RDPSs:

- App RDPS which run on a host device that is intended or reasonably foreseen to be operated in a:
  - **fully controlled physical operational environment** - POE.FullyControlled
  - **partially controlled physical operational environment** - POE.PartiallyControlled
  - **mobile operational environment** - POE.Mobile.

For the physical operational environment, the following environments are addressed for Cloud RDPSs:

- Cloud RDPS runs on a host device that is intended or reasonably foreseen to be operated in a
  - **fully controlled physical operational environment** - POE.FullyControlled.

## 4.4 Interface

The present document addresses the following interfaces of SHGPVA:

- **human interface** - IF.Human
- **machine interface** - IF.Machine
- **logical interface** - IF.Logical
- **physical interface** - IF.Physical.

## 4.5 Distribution of security functions

The present document addresses the distribution of security functions among the SHGPVA and other products with digital elements in the SHGPVA's context (e.g. host devices for SHGPVA's architectural components that are software) by the following expressions used to formulate the technical requirements specifications in clause [5.1](#).

"The SHGPVA shall [...] use [some expression related to security functions]" means:

- the SHGPVA itself provides those security functions which are always used, or
- other products with digital elements in the SHGPVA's context provide those security functions which are always used by the SHGPVA.

"The SHGPVA shall [...] support [some expression related to security functions]" means:

- the SHGPVA itself provides those security functions, or
- other products with digital elements in the SHGPVA's context provide those security functions.

"The SHGPVA shall [...] provide [some expression related to security functions]" means that the SHGPVA itself provides those security functions.

Situations where the SHGPVA itself does not provide security functions that are required to be used or supported by the SHGPVA and other products with digital elements in the SHGPVA's context do not provide those security functions, are addressed in the requirement [USERNOT-NOSECFUC] in clause [5.1.12](#).

## 4.6 Users

The present document addresses the following users of SHGPVA:

- Consumers for private usage

- Manufactures for integration in other products with digital elements intended for consumers.

## 4.7 Use cases

### 4.7.1 General

The present document addresses all use cases that can be constructed by the previous elements of clause 4.

### 4.7.2 Use case profiles

In order to classify use cases and to define security profiles the following use case profiles are defined. Those definitions make use of impact classes of product functions. The functions covered by the present document are provided in clause 4.1, their impact classes in annex D.

#### Use case profile for low impact functions

The use case profile for low impact functions bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAI.TIME) of a SHGPVA's function falls under IMP.Low.

Example use cases:

The usage of a SHGPVA to access information that is derived from public data.

#### Use case profile for medium impact functions

The use case profile for medium impact functions bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAI.TIME) of a SHGPVA's function falls under IMP.Medium.

Example use cases:

The usage of a SHGPVA:

- to access information that is derived from general user data or
- to modify general user data.

#### Use case profile for high impact functions

The use case profile for high impact functions bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAI.TIME) of a SHGPVA's function falls under IMP.High.

Example use cases:

The usage of a SHGPVA to access information that is derived from a user's health data.

## 4.8 Security Profiles

Based on the use case profiles defined in clause 4.7.2 the following security profiles with assigned requirements in table 1 are defined:

- security profile for low impact functions
- security profile for medium impact functions
- security profile for high impact functions.

562

Table 1: Security profiles with corresponding requirements

| requirement           | security profile for |                         |                       |
|-----------------------|----------------------|-------------------------|-----------------------|
|                       | low impact functions | medium impact functions | high impact functions |
| [NKEV-MKAV]           | X                    | X                       | X                     |
| [NKEV-SUM-SUPPORT]    | X                    | X                       | X                     |
| [NKEV-SUM-PROVIDE]    | X                    | X                       | X                     |
| [NKEV-SUM-AUTO]       | X                    | X                       | X                     |
| [NKEV-SUM-NOTIF]      | X                    | X                       | X                     |
| [SDC-AUM-FH]          | X                    | X                       | X                     |
| [SDC-SUM-AUTO]        | X                    | X                       | X                     |
| [SDC-SUM-NOTIF]       | X                    | X                       | X                     |
| [SDC-FRM]             | X                    | X                       | X                     |
| [ACM-FH]              | X                    | X                       | X                     |
| [AUM-FH]              | X                    | X                       | X                     |
| [AUTHZ-LP]            | X                    | X                       | X                     |
| [AUTHZ-R]             | X                    | X                       | X                     |
| [INT-SWPCK]           | X                    | X                       | X                     |
| [INT-COM]             | X                    | X                       | X                     |
| [CONF-SSM]            | X                    | X                       | X                     |
| [CONF-COM]            | X                    | X                       | X                     |
| [AVAI-TIME-RECO-POW]  | X                    | X                       | X                     |
| [AVAI-TIME-NETW]      | X                    | X                       | X                     |
| [AVAI-TIME-RECO-NETW] | X                    | X                       | X                     |
| [AVAI-TIME-OUTA-NOT]  |                      | X                       | X                     |
| [AVAI-TIME-PREV-NOT]  |                      |                         | X                     |
| [AVAI-TIME-NET-PRIO]  |                      | X                       | X                     |
| [AVAI-TIME-RES-PRIO]  |                      | X                       | X                     |
| [AVAI-TIME-IMP-AMP]   |                      | X                       | X                     |
| [AVAI-TIME-DOS-RATE]  |                      |                         | X                     |
| [AVAI-SUM-SCHEDULE]   |                      | X                       | X                     |
| [LAS-INVAL]           | X                    | X                       | X                     |
| [LAS-INSAN]           | X                    | X                       | X                     |
| [LAS-PHY-INF]         | X                    | X                       | X                     |
| [LAS-LOGIC-INF]       | X                    | X                       | X                     |
| [LAS-APP]             | X                    | X                       | X                     |
| [LAS-SBOOT]           |                      |                         | X                     |
| [USERNOT-NOSECFUC]    | X                    | X                       | X                     |
| [DMIN-DJST]           | X                    | X                       | X                     |
| [LOG-LOW]             | X                    |                         |                       |
| [LOG-MEDIUM]          |                      | X                       |                       |
| [LOG-HIGH]            |                      |                         | X                     |
| [LOG-TIME]            | X                    | X                       |                       |
| [LOG-TIME-HIGH]       |                      |                         | X                     |
| [LOG-STORAGE]         |                      | X                       | X                     |
| [LOG-BACKUP]          |                      |                         | X                     |

563

## 5 Requirements specifications

564

### 5.1 Product's technical requirements specifications

565

#### 5.1.1 Known exploitable vulnerabilities

566

##### 5.1.1.1 [NKEV-MKAV] No known exploitable vulnerabilities

567

568 In accordance with the vulnerability handling specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1],  
 569 the SHGPVA shall prior to making available on the market have no insufficiently mitigated known exploitable  
 570 vulnerabilities.

NOTE 1: The known exploitable vulnerabilities that occur after making the SHGPVA available on the market are subject to the vulnerability handling in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1].

NOTE 2: Typically, products are supplied with all necessary security updates during commissioning.

#### 5.1.1.2 [NKEV-SUM-SUPPORT] Secure software update mechanism

The SHGPVA shall support software update mechanisms, that allow to update every part of the SHGPVA's software, except for parts of the SHGPVA's software, that are immutable due to technical reasons.

EXAMPLE: A mobile RDPS is installed on a device that supports updating the mobile RDPS (e.g. via app-stores)

#### 5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components

All architectural components of the SHGPVA that include core software shall provide software update mechanisms, that allow to update every part of the architectural components software, except for parts of the architectural components software, that are immutable due to security.

NOTE: A mobile application typically does not need to provide an update mechanism

#### 5.1.1.4 [NKEV-SUM-AUTO] Automated security updates

The SHGPVA shall support the automated update of its software.

#### 5.1.1.5 [NKEV-SUM-NOTIF] Update notifications

The SHGPVA shall support the automated notification of its consumers, when updates of its software are available.

### 5.1.2 Default configuration

#### 5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm

The SHGPVA shall by default be configured to use authentication mechanisms that meet

- the authentication mechanisms strengths specified in clause [E.3.1](#); and
- the minimal authentication mechanisms' strength determined by table [3](#),

except for connection functions.

NOTE: The support of authentication for functions whose use can cause harm is addressed in [AUM-FH].

#### 5.1.2.2 [SDC-SUM-AUTO] Default configuration of automated security updates

The SHGPVA shall by default be configured to use automated software update mechanisms for its software.

NOTE: The support of automated security updates is addressed in [NKEV-SUM-AUTO].

#### 5.1.2.3 [SDC-SUM-NOTIF] Default configuration of update notifications

The SHGPVA shall by default be configured to use automated notification of its consumers, when updates of the SHGPVA's software are available.

NOTE: The support of update notification is addressed in [NKEV-SUM-NOTIF].

### 5.1.2.4 [SDC-FRM] Factory reset to restore the default state

The SHGPVA shall provide a factory reset mechanism that allows a consumer to restore the default state, including the deletion of all user data, installed applications, and configurations deviating from the default state.

NOTE 1: It is also possible that the factory reset will delete the installed security updates if these are installed automatically or on request when the device is commissioned again.

NOTE 2: ANNEX II 8. d) of Regulation (EU) 2024/2847 [i.1] contains legal obligations on how consumers of the SHGPVA are informed about secure decommissioning of the SHGPVA.

## 5.1.3 Authentication and access control mechanisms

### 5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm

The SHGPVA shall use access control mechanisms to control entities' use of functions whose use can cause harm, where the applicability of this requirement is determined by table 2 except for connection functions.

**Table 2: Assignment for access control mechanisms**

|                                                                                                 |                                                                                          |                         | impact class for function, whose use can cause harm |               |               |
|-------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|-------------------------|-----------------------------------------------------|---------------|---------------|
|                                                                                                 |                                                                                          |                         | IMP.FH.Low                                          | IMP.FH.Medium | IMP.FH.High   |
| Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input | COM.StrictLocal via IF.Any                                                               | POE.FullyControlled     | N/A                                                 | N/A           | applicable[*] |
|                                                                                                 |                                                                                          | POE.PartiallyControlled | N/A                                                 | applicable[*] | applicable[*] |
|                                                                                                 |                                                                                          | POE.Mobile              | applicable[*]                                       | applicable[*] | applicable[*] |
|                                                                                                 | COM.Local via IF.HumanPhysical                                                           | POE.FullyControlled     | N/A                                                 | applicable    | applicable    |
|                                                                                                 |                                                                                          | POE.PartiallyControlled | applicable                                          | applicable    | applicable    |
|                                                                                                 |                                                                                          | POE.Mobile              | applicable                                          | applicable    | applicable    |
|                                                                                                 | COM.Local via a non-IF.HumanPhysical<br>COM.Adjacent via IF.Any<br>COM.Public via IF.Any | POE.Any                 | applicable                                          | applicable    | applicable    |
|                                                                                                 |                                                                                          |                         | applicable                                          | applicable    | applicable    |
|                                                                                                 |                                                                                          |                         | applicable                                          | applicable    | applicable    |

For protection measures that are labelled with [\*] it is not required that the SHGPVA uses access control mechanisms for its following functions:

- factory reset function.

### 5.1.3.2 [AUM-FH] Authentication for functions whose use can cause harm

The SHGPVA shall support authentication mechanisms, to authenticate entities using functions whose use can cause harm before generating function output, where

- the authentication mechanisms strengths' are specified in clause [E.3.1](#); and
- the minimal required authentication strength is determined by table [3](#),

except for connection functions.

**Table 3: Assignment for authentication mechanisms strengths**

|                                                                                                 |                                      |                         | impact class for function, whose use can cause harm |                |                  |
|-------------------------------------------------------------------------------------------------|--------------------------------------|-------------------------|-----------------------------------------------------|----------------|------------------|
|                                                                                                 |                                      |                         | IMP.FH.Low                                          | IMP.FH.Medium  | IMP.FH.High      |
| Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input | COM.StrictLocal via IF.Any           | POE.FullyControlled     | N/A                                                 | N/A            | AUTH.Normal[*]   |
|                                                                                                 |                                      | POE.PartiallyControlled | N/A                                                 | AUTH.Basic[*]  | AUTH.Normal[*]   |
|                                                                                                 |                                      | POE.Mobile              | AUTH.Basic[*]                                       | AUTH.Normal[*] | AUTH.Enhanced[*] |
|                                                                                                 | COM.Local via IF.HumanPhysical       | POE.FullyControlled     | N/A                                                 | AUTH.Basic     | AUTH.Normal      |
|                                                                                                 |                                      | POE.PartiallyControlled | AUTH.Basic                                          | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 |                                      | POE.Mobile              | AUTH.Basic                                          | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 | COM.Local via a non-IF.HumanPhysical | POE.Any                 | AUTH.Normal                                         | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 | COM.Adjacent via IF.Any              |                         | AUTH.Normal                                         | AUTH.Normal    | AUTH.Enhanced    |
|                                                                                                 | COM.Public via IF.Any                |                         | AUTH.Normal                                         | AUTH.Enhanced  | AUTH.Enhanced    |

For protection measures that are labelled with [1] it is not required that the SHGPVA uses authentication mechanisms for its following functions:

- factory reset function

### 5.1.3.3 [AUTHZ-LP] Least privilege in authorization policies

The SHGPVA shall use an authorization policy that only grants permissions that are necessary for the intended purpose.

EXAMPLE: A SHGPVA with just one consumer grants that consumer all permissions.

### 5.1.3.4 [AUTHZ-R] Revocability of granted permissions

The SHGPVA shall support the revocation of any permission granted by an authorized entity.

EXAMPLE: An administrative consumer can revoke permissions granted to another consumer.

## 5.1.4 Integrity protection

### 5.1.4.1 [INT-SWPCK] Software package verification

The SHGPVA shall use software package verification mechanisms to verify the integrity and authenticity of software packages prior to installation where the software package verification mechanism's strength levels are specified in clause [E.6.1](#) and where the minimal software package verification mechanism's strength is determined by table [4](#).

NOTE: The requirement addresses software packages that are updates and new software to be installed.

**Table 4: Assignment of the software package verification mechanism's strength levels for the verification of software packages**

|                                                                            |                                       | highest IMP.INT of the SHGPVA's integrity relevant functions |                   |                     |
|----------------------------------------------------------------------------|---------------------------------------|--------------------------------------------------------------|-------------------|---------------------|
|                                                                            |                                       | IMP.INT.Low                                                  | IMP.INT.Medium    | IMP.INT.High        |
| Attack Surface determined by the COM of RDPS or MP over which the software | COM.StrictLocal                       | INT.SW.VER.Basic                                             | INT.SW.VER.Basic  | INT.SW.VER.Basic    |
|                                                                            | COM.Local, COM.Adjacent or COM.Public | INT.SW.VER.Normal                                            | INT.SW.VER.Normal | INT.SW.VER.Enhanced |
|                                                                            |                                       |                                                              |                   |                     |

#### 5.1.4.2 [INT-COM] Communication of integrity relevant data

The SHGPVA shall use integrity protecting communication mechanisms to protect the integrity of communicated integrity relevant data, where the corresponding integrity protection measures strengths are specified in clause [E.6.2](#) and the minimal required integrity protection measures' strength are determined by table [5](#).

**Table 5: Assignment of protection mechanisms strength level for the integrity protection of outgoing data and for the integrity verification of incoming data.**

|                                                                                                      |                                             |                         | integrity relevant data impact class |                  |                  |
|------------------------------------------------------------------------------------------------------|---------------------------------------------|-------------------------|--------------------------------------|------------------|------------------|
|                                                                                                      |                                             |                         | IMP.INT.Low                          | IMP.INT.Medium   | IMP.INT.High     |
| Attack Surface determined by COM, IF and POE of RDPS or MP that communicates integrity relevant data | COM.StrictLocal via IF.Machine              | POE.Any                 | INT.COM.Basic                        | INT.COM.Basic    | INT.COM.Basic    |
|                                                                                                      | COM.Local via IF.Machine or IF.HumanLogical | POE.FullyControlled     | INT.COM.Basic                        | INT.COM.Basic    | INT.COM.Normal   |
|                                                                                                      |                                             | POE.PartiallyControlled | INT.COM.Basic                        | INT.COM.Normal   | INT.COM.Enhanced |
|                                                                                                      |                                             | POE.Uncontrolled        | INT.COM.Normal                       | INT.COM.Enhanced | INT.COM.Enhanced |
|                                                                                                      | COM.Adjacent via IF.Any                     | POE.Any                 | INT.COM.Enhanced                     | INT.COM.Enhanced | INT.COM.Enhanced |
|                                                                                                      | COM.Public via IF.Any                       |                         | INT.COM.Enhanced                     | INT.COM.Enhanced | INT.COM.Enhanced |

#### 5.1.5 Confidentiality protection

##### 5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data

The SHGPVA shall use confidentiality protecting secure storage mechanisms for persistently stored confidential data, where the mechanisms' strength are specified in clause [E.4.1](#) and the minimal required mechanisms' strength are determined by table [6](#).

**Table 6: Assignment for confidentiality protecting secure storage mechanisms**

|                                                                                           |                         | confidentiality impact class for persistently stored confidential data |                   |                   |
|-------------------------------------------------------------------------------------------|-------------------------|------------------------------------------------------------------------|-------------------|-------------------|
|                                                                                           |                         | IMP.CONF.Low                                                           | IMP.CONF.Medium   | IMP.CONF.High     |
| Attack Surface determined by POE of RDPS or MP that persistently stores confidential data | POE.FullyControlled     | N/A                                                                    | N/A               | N/A               |
|                                                                                           | POE.PartiallyControlled | N/A                                                                    | CONF.SSM.Basic[1] | CONF.SSM.Normal   |
|                                                                                           | POE.Mobile              | CONF.SSM.Basic[1]                                                      | CONF.SSM.Normal   | CONF.SSM.Enhanced |

For protection measures labelled with [1], it is not required that the SHGPVA uses confidentiality protecting persistent storage for confidential data for confidential data:

- which is persistently stored on non-removable storage

##### 5.1.5.2 [CONF-COM] Communication of confidential data

The SHGPVA shall use confidentiality protecting communication mechanisms to protect the confidentiality of communicated confidential data, where the corresponding confidentiality protection measures strengths are specified in clause [E.5.1](#) and the minimal required confidentiality protection measures' strength are determined by table [7](#).

**Table 7: Assignment of protection mechanisms strength level for the confidentiality of communicated data.**

|                                  |  |                     | confidential data impact class |                 |                 |
|----------------------------------|--|---------------------|--------------------------------|-----------------|-----------------|
|                                  |  |                     | IMP.CONF.Low                   | IMP.CONF.Medium | IMP.CONF.High   |
| Attack Surface determined by COM |  | POE.FullyControlled | N/A                            | N/A             | CONF.COM.Normal |

|  |                                             |                         | confidential data impact class |                   |                   |
|--|---------------------------------------------|-------------------------|--------------------------------|-------------------|-------------------|
|  |                                             |                         | IMP.CONF.Low                   | IMP.CONF.Medium   | IMP.CONF.High     |
|  | COM.Local via IF.Machine or IF.HumanLogical | POE.PartiallyControlled | N/A                            | CONF.COM.Basic    | CONF.COM.Normal   |
|  |                                             | POE.Uncontrolled        | CONF.COM.Basic                 | CONF.COM.Normal   | CONF.COM.Enhanced |
|  | COM.Adjacent via IF.Any                     | POE.Any                 | CONF.COM.Enhanced              | CONF.COM.Enhanced | CONF.COM.Enhanced |
|  | COM.Public via IF.Any                       |                         | CONF.COM.Enhanced              | CONF.COM.Enhanced | CONF.COM.Enhanced |

671

## 672 5.1.6 Data minimization

### 673 5.1.6.1 [DMIN-DJST] Documented justification of processed data

674 The SHGPVA shall only process confidential data according to its intended purpose.

## 675 5.1.7 Availability protection

### 676 5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power

677 The MP shall use a mechanism to resume connectivity and functionality in the case of a loss of power as soon as the  
678 power supply is restored.

### 679 5.1.7.2 [AVAI-TIME-NETW] Local operation

680 Where network connectivity is not necessary for a time sensitive function to operate, the SHGPVA shall ensure the  
681 operability of this function in the case of a loss of network access.

### 682 5.1.7.3 [AVAI-TIME-RECO-NETW] Restoration after loss of network connection

683 The SHGPVA shall use a mechanism to reconnect cleanly after a loss of network connection.

684 EXAMPLE: A SHGPVA loses connection to the local network as the network is temporarily unavailable. After  
685 recognizing the restored network, the SHGPVA reconnects after a randomized delay to reconnect  
686 cleanly.

687 NOTE: *Reconnecting cleanly* normally involves resuming connectivity to network in an expected, operational  
688 and stable state and in an orderly fashion taking the capability of the infrastructure into consideration.

### 689 5.1.7.4 [AVAI-TIME-OUTA-NOT] Notify non-availability

690 Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the SHGPVA, the  
691 SHGPVA shall use a mechanism to warn the consumer before or at least during a IMP.AVAI.TIME.Medium or higher  
692 function becomes unavailable due to CPU, memory, power or network limitations.

693 EXAMPLE 1: A cloud RDPS recognises a non-availability of its MP and sends a notification to the consumer.

694 EXAMPLE 2: A SHGPVA with a network-dependend IMP.AVAI.TIME.High function recognizes a low  
695 bandwidth and sends a notification to the consumer.

### 696 5.1.7.5 [AVAI-TIME-PREV-NOT] Notify upcoming limitation

697 Where at least one time sensitive function with IMP.AVAI.TIME.High is provided by the SHGPVA, the SHGPVA  
698 shall use a mechanism to notify the consumer when the SHGPVA recognizes upcoming resource limitations.

699 EXAMPLE: A battery powered SHGPVA recognizes low battery and sends a notification to the consumer.



### 5.1.7.6 [AVAI-TIME-NET-PRIO] Network prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher with the need of network connectivity for operation is provided by the SHGPVA, the SHGPVA shall use a mechanism to prioritize the execution of these functions in the case of a network resource conflict.

### 5.1.7.7 [AVAI-TIME-RES-PRIO] Resource prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the SHGPVA, the SHGPVA shall use a mechanism to prioritize the execution of these functions in the case of a CPU, memory or power resource conflict.

EXAMPLE: The SHGPVA uses the following prioritization in case of resource conflict (high to low priority):

- 1. Time sensitive availability relevant functions
- 2. Authenticated consumer commands
- 3. Background tasks (e.g. logging, updates)

NOTE: At least the following resources can cause a processing resource conflict: CPU, memory, power

### 5.1.7.8 [AVAI-TIME-IMP-AMP] Amplification control

Where at least one function, whose use can impact the availability of other devices, services or networks with IMP.FH.DSN.Medium or higher is provided by the SHGPVA, the SHGPVA shall use mechanisms to prevent effective amplification of requests or network traffic of these functions.

EXAMPLE: An ICMP request has an amplification factor of three. Then the response time is artificially extended by a factor of tree per destination to have no effective gain in bandwidth.

### 5.1.7.9 [AVAI-TIME-DOS-RATE] Incoming rate limiting

Where at least one time sensitive function with IMP.AVAI.TIME.High AND at least one machine interface are provided by the SHGPVA, the SHGPVA shall use mechanisms to discard packets from a source if it sends an unusually high number of requests, whose execution could result in a resource conflict.

### 5.1.7.10 [AVAI-SUM-SCHEDULE] Scheduling of updates

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the SHGPVA, the SHGPVA shall support the scheduling of the application of updates that can impact the availability of these function with IMP.AVAI.TIME.Medium or higher.

## 5.1.8 Impact minimization

### 5.1.9 Limit attack surface

#### 5.1.9.1 [LAS-INVAL] Validation of external data input

The SHGPVA shall use input validation mechanisms for all external data input.

EXAMPLE: If an application expects the input to be an email address, any input that does not conform to the format of an e-mail address will be rejected.

NOTE 1: The specific pattern to accept external data input depends amongst others on the manner the external data input is intended to be processed. This means that an acceptance pattern for broad purposes (such as administration via a "Secure Shell") is typically less specific than an acceptance pattern for a specific purpose (such as a measurement value of a specific format to be stored).

NOTE 2: Typically the validation of different parts of the input will happen at different layers. Network layer of the operating system verify only information relevant to the network. An application verifies only input that is relevant to that application.

### 5.1.9.2 [LAS-INSAN] Sanitization of external data input

The SHGPVA shall use input sanitization mechanisms before using external data input as function input, where the validation of external data input cannot prevent potential incidents triggered by the external data input.

EXAMPLE: If external data input is amongst others intended to be stored via a database service, escape characters and other database service specific commands are removed from the external data input, before it is processed by the database service.

### 5.1.9.3 [LAS-PHY-INF] Only necessary physical interfaces

A hardware MP shall only provide physical interfaces, that are necessary for the SHGPVA's intended purpose.

### 5.1.9.4 [LAS-LOGIC-INF] Only necessary logical interfaces active by default

The SHGPVA shall by default only use logical interfaces, that are necessary for its intended purpose.

### 5.1.9.5 [LAS-APP] Only necessary apps by default

The SHGPVA shall by default only use application softwares, that are necessary for its intended purpose.

### 5.1.9.6 [LAS-SBOOT] Secure boot

Where at least one function, whose use can cause harm with IMP.FH.High is provided by the SHGPVA and the SHGPVA includes a hardware MP, the hardware MP shall use a bootloader function that only executes core software at startup, whose integrity and authenticity is verified.

NOTE: The requirement corresponds to the verified boot capability in ETSI EN 304 623 V1.1.1 [i.5].

## 5.1.10 Logging and monitoring mechanisms

### 5.1.10.1 [LOG-LOW] Events to log for low risk SHGPVA

Where the SHGPVA has a function, whose use can cause harm of impact class low as its highest function impact class, the SHGPVA shall support logging mechanisms to create audit events for every:

- change of configuration affecting core software
- starts, shutdowns or other changes of operational states of core software.
- errors of the core software.

### 5.1.10.2 [LOG-MEDIUM] Events to log for medium risk SHGPVA

Where the SHGPVA has a function, whose use can cause harm of impact class medium as its highest function impact class, the SHGPVA shall use logging mechanisms to create audit events for every

- unsuccessful authentication attempt
- change of configuration affecting core software
- starts, shutdowns or other changes of operational states of core software.
- errors of the core software
- unsuccessful attempt of an identity to gain additional privileges
- unsuccessful attempt of an identity to access a data asset or function asset.

### 773 5.1.10.3 [LOG-HIGH] Events to log for high risk SHGPVA

774 Where the SHGPVA has a function, whose use can cause harm of impact class high as its highest function impact class,  
775 the SHGPVA shall use logging mechanisms to create audit events for every

- 776 • every authentication attempt
- 777 • change of configuration affecting core software
- 778 • starts, shutdowns or other changes of operational states of core software.
- 779 • change of configuration affecting application software whom realize function, whose use can cause harm of  
780 impact class high.
- 781 • starts, shutdowns or other changes of operational states of application software whom realize function, whose  
782 use can cause harm of impact class high.
- 783 • errors of the core software
- 784 • errors of the application software whom realize function, whose use can cause harm of impact class high.
- 785 • every attempt of an identity to gain additional privileges
- 786 • every attempt of an identity to access a data asset or function asset.

### 787 5.1.10.4 [LOG-TIME] Timestamps for logs

788 Where the SHGPVA does not has a function, whose use can cause harm of impact class high, the SHGPVA shall use at  
789 least a time service or function to include a timestamp in every audit event, created by the SHGPVA.

### 790 5.1.10.5 [LOG-TIME-HIGH] Real-Timestamps for logs

791 Where the SHGPVA has a function, whose use can cause harm of impact class high as its highest function impact class,  
792 the SHGPVA shall use a real-time service or clock to include a real-time timestamp in every audit event, created by the  
793 SHGPVA.

### 794 5.1.10.6 [LOG-STORAGE] Persistently store logfiles

795 Where the SHGPVA has a function, whose use can cause harm of impact class medium or higher as its highest function  
796 impact class, the SHGPVA shall use integrity protecting secure storage mechanisms to store every audit event created  
797 by the SHGPVA persistently.

### 798 5.1.10.7 [LOG-BACKUP] Backup of logfiles

799 Where the SHGPVA has a function, whose use can cause harm of impact class high as its highest function impact class,  
800 the SHGPVA shall automatically back up its audit events to another device or another part of the SHGPVA that is in  
801 another physical location.

## 802 5.1.11 Deletion mechanisms

## 803 5.1.12 Other product's technical requirements specifications

### 804 5.1.12.1 [USERNOT-NOSECFUC] User notifications on not available security 805 functions

806 The SHGPVA shall notify a consumer when security functions that are supposed to be used or supported by the  
807 SHGPVA are not available.

## 5.2 Requirements specifications for vulnerability handling activities related to the product

The requirements specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1] shall be fulfilled for the SHGPVA.

---

## 6 Assessing for compliance with requirements

### 6.1 Assessing for compliance with product's technical requirements specifications

#### 6.1.1 General

In order to assess the compliance with the requirements listed in clause 5.1 of the present document, the assessment procedures described in clause 6.1 are to be followed. When performing assessments, the distribution of security functions (see clause 4.5) are to be considered, including whether the product provides security functions itself, demands them from other products with digital elements within its context, or supplies them to other products with digital elements.

If there are already existing evidences (e.g. provided by manufacturers of components that are integrated in the SHGPVA) that:

- are covering the same assessment activities as described in clause 6.1, and
- are valid for the moment of the assessment to be performed under clause 6.1,

those existing evidences can be used for the "assignment of verdict" and as "supporting evidence".

#### 6.1.2 Known exploitable vulnerabilities

##### 6.1.2.1 Assessment criteria for [NKEV-MKAV]

#### 6.1.3 Default configuration

##### 6.1.3.1 Assessment criteria for [SDC-FRM]

###### Assessment objective:

The assessment functionally determines whether all user data, installed applications, and configurations deviating from the default state are erased after using the factory reset mechanism.

###### Assessment preparation:

- Documentation on how the factory reset mechanism can be accessed.
- The SHGPVA shall be set up and some configuration changes shall be created and persistently stored.
- Where the SHGPVA supports the storage of user data, some user data shall be created and persistently stored on the SHGPVA.
- Where the SHGPVA supports the installation of applications, some common application for the SHGPVA shall be installed.

NOTE: user data also encompasses cryptographic keys, e.g. Wi-Fi® passwords, certificates.

###### Assessment activities:

- 842 • An authorised entity shall start the factory reset mechanism.
- 843 • The erasure of user data, applications and configurations shall be validated.
- 844 - The restoration of the device settings to their default state shall be validated.
- 845 • Attempts to access any previous user accounts or data shall be made.

#### 846 **Assignment of verdict:**

847 The verdict PASS shall be assigned when all user data, installed applications, and configurations deviating from the  
848 default state are erased

849 The verdict FAIL shall be assigned otherwise.

#### 850 **Supporting Evidence:**

- 851 • Description of the performed test
- 852 • All test records of the performed test.

### 853 **6.1.4 Authentication and access control mechanisms**

#### 854 **6.1.4.1 Assessment criteria for [ACM-FH]**

##### 855 **Assessment objective:**

856 The assessment covers:

- 857 • a conceptual assessment of ACM-FH
  - 858 • a functional completeness assessment on the SHGPVA capabilities that are addressed by ACM-FH
  - 859 • a functional sufficiency assessment of each access control mechanism used by the SHGPVA to fulfil ACM-FH
- 860 based on the default configuration required by clause [5.1.2](#).

##### 861 **Assessment preparation:**

862 The following documentation for the SHGPVA shall be complete:

- 863 • a list of SHGPVA's functions whose use can cause harm
- 864 • for each function, whose use can cause harm:
  - 865 - its impact class impact class for function, whose use can cause harm
  - 866 - the physical operational environment of the architectural component that performs the function
  - 867 - for each of the function's trigger input possibilities:
    - 868 ▪ the interface and communication type
    - 869 ▪ a list of corresponding access control mechanisms including their default authorization policy.

870 The following test setups shall be prepared:

- 871 • a test setup for identifying functions, their trigger input possibilities and corresponding access control  
872 mechanisms based on a sample SHGPVA in default configuration,
- 873 • for each access control mechanism, a test setup that allows privilege escalation attacks from authenticated  
874 entities and unauthorized access attempts of unauthenticated entities.

##### 875 **Assessment activities:**

- 876 • The SHGPVA's conformity to ACM-FH shall be validated based on the documentation.

- 877 • The correctness and completeness of the documentation shall be verified by:
- 878     - an inspection of the SHGPVA for functions and related access control mechanisms that are accessible via
- 879         physical human interfaces
- 880     - a scan of the SHGPVA for functions and related access control mechanisms that are accessible via
- 881         logical interfaces.
- 882 • For each access control mechanism, its correct implementation shall be verified based on attempts to violate
- 883     the authorization policy by:
- 884     - privilege escalation of authenticated entities based on the default authorization policy
- 885     - unauthorized usage of function, whose use can cause harm by unauthenticated entities based on the
- 886         default authorization policy.

#### 887 **Assignment of verdict:**

888 The verdict PASS shall be assigned if:

- 889 • the documentation indicates the SHGPVA's conformity to ACM-FH; and
- 890 • the verification of the correctness and completeness of the documentation was successful; and
- 891 • the verification of the correct implementation of each access control mechanism was successful.

892 The verdict FAIL shall be assigned otherwise.

#### 893 **Supporting Evidence:**

- 894 • records of the validation of the documentation
- 895 • descriptions of the performed tests and records of performed tests to verify the correctness and completeness
- 896     of the documentation
- 897 • descriptions of the performed tests and records of performed tests to verify the correct implementation of each
- 898     access control mechanism

### 899 **6.1.4.2 Assessment criteria for [AUM-FH]**

#### 900 **Assessment objective:**

901 The assessment covers:

- 902 • a conceptual assessment of AUM-FH
- 903 • a functional completeness assessment on the SHGPVA capabilities that are addressed by AUM-FH
- 904 • a functional sufficiency assessment of each authentication mechanism used by the SHGPVA to fulfil
- 905     AUM-FH

906 based on the default configuration required by clause [5.1.2](#).

#### 907 **Assessment preparation:**

908 The following documentation for the SHGPVA shall be complete:

- 909 • a list of SHGPVA's functions whose use can cause harm
- 910 • for each function, whose use can cause harm:
- 911     - its impact class impact class for function, whose use can cause harm
- 912     - the physical operational environment of the architectural component that performs the function
- 913     - for each of the function's trigger input possibilities:

- 914                   ▪     the interface and communication type
- 915                   ▪     a list of corresponding authentication mechanisms including:
  - 916                             •     the authentication mechanisms' strength
  - 917                             •     the type of authentication factors.

918   The following test setups shall be prepared:

- 919             •     a test setup for identifying functions, their trigger input possibilities and corresponding authentication mechanisms based on a sample SHGPVA in default configuration,
- 920
- 921             •     for each authentication mechanism, a test setup defined by the test cases provided in clause [E.3](#) according to
- 922                   the needs determined by its strength and the type of its authentication factors.

#### 923   **Assessment activities:**

- 924             •     The SHGPVA's conformity to ACM-FH shall be validated based on the documentation.
- 925             •     The correctness and completeness of the documentation shall be verified by:
  - 926                   -     an inspection of the SHGPVA for functions and related authentication mechanisms that are accessible
  - 927                             via physical human interfaces
  - 928                   -     a scan of the SHGPVA for functions and related authentication mechanisms that are accessible via
  - 929                             logical interfaces.
- 930             •     For each authentication mechanism, its correct implementation shall be verified based on the test cases
- 931                   provided in clause [E.3](#) according to the needs determined by its strength and the type of its authentication
- 932                   factors.

#### 933   **Assignment of verdict:**

934   The verdict PASS shall be assigned if:

- 935             •     the documentation indicates the SHGPVA's conformity to ACM-FH; and
- 936             •     the verification of the correctness and completeness of the documentation was successful; and
- 937             •     the verification of the correct implementation of each authentication mechanism was successful.

938   The verdict FAIL shall be assigned otherwise.

#### 939   **Supporting Evidence:**

- 940             •     records of the validation of the documentation
- 941             •     descriptions of the performed tests and records of performed tests to verify the correctness and completeness
- 942                   of the documentation
- 943             •     descriptions of the performed tests and records of performed tests to verify the correct implementation of each
- 944                   authentication mechanism.

### 945   6.1.4.3     Assessment criteria for [AUTHZ-LP]

#### 946   **Assessment objective:**

947   The assessment covers:

- 948             •     a conceptual assessment of AUTHZ-LP.

949   based on the default configuration required by clause [5.1.2](#).

#### 950   **Assessment preparation:**

951 The following documentation for the SHGPVA shall be complete:

- 952 • a description of the authorization policys in default configuration including:
  - 953 - a list of granted permissions for entities on function, whose use can cause harm and
  - 954 - for each granted permission, a justification that it is necessary for the intended purpose.

955 **Assessment activities:**

- 956 • The SHGPVA's conformity to {requirement\_authz:AUTHZ-LP} shall be validated based on the  
957 documentation.

958 **Assignment of verdict:**

959 The verdict PASS shall be assigned if:

- 960 • the documentation indicates the SHGPVA's conformity to AUTHZ-LP.

961 The verdict FAIL shall be assigned otherwise.

962 **Supporting Evidence:**

- 963 • records of the validation of the documentation.

964 **6.1.4.4 Assessment criteria for [AUTHZ-R]**

965 **Assessment objective:**

966 The assessment covers:

- 967 • a functional sufficiency assessment to ensure the SHGPVA supports revocation of any granted permissions.

968 **Assessment preparation:**

969 The following documentation for the SHGPVA shall be complete:

- 970 • a list of mechanisms to grant permissions for entities on function, whose use can cause harm.

971 The following test setups shall be prepared:

- 972 • for each mechanism to grant permissions, a test setup for granting and revoking permissions for entities on  
973 function, whose use can cause harm.

974 **Assessment activities:**

- 975 • For each mechanism to grant permissions, the revocability of grantable permissions shall be verified by:
  - 976 - granting permissions to an entity,
  - 977 - revoking the permissions, and
  - 978 - attempting use permissions after revocation.

979 **Assignment of verdict:**

980 The verdict PASS shall be assigned if:

- 981 • for each mechanism to grant permissions, access is denied after revocation.

982 The verdict FAIL shall be assigned otherwise.

983 **Supporting Evidence:**

- 984 • descriptions of the performed tests and records of performed tests to verify the correct implementation of  
985 AUTHZ-R.



## 6.1.5 Integrity protection

## 6.1.6 Confidentiality protection

## 6.1.7 Data minimization

### 6.1.7.1 Assessment criteria for [DMIN-DJST]

#### Assessment objective:

The assessment covers:

- a conceptual assessment of Documented justification of processed data
- a functional sufficiency assessment of each mechanism and/or configuration used by the SHGPVA to fulfil Documented justification of processed data
- a functional completeness assessment on the SHGPVA capabilities that are addressed by Documented justification of processed data.

#### Assessment preparation:

The following documentation for the SHGPVA shall be complete:

- a list of all documented data sources and destinations to which processed data is transmitted or made accessible (if applicable), processed by the SHGPVA in its default configuration;
- a list of all data assets processed by the SHGPVA whose impact class for confidential SHGPVA data is IMP.CONF.Low or higher;
- for each documented confidential data asset, the associated rationale for its necessity explaining why its processing is necessary for the intended purpose of the SHGPVA;
- a description of the mechanisms and/or configurations used to ensure data minimization (e.g. code modules for data filtering, configuration settings that limit data intake, architectural diagrams showing data flows, or policies that prevent unnecessary processing).

NOTE: The documentation of sources and destinations may be combined where a data flow is bidirectional or where source and destination are the same entity.

The following shall be prepared:

- a methodology capable of detecting and listing all data sources actually processed by an SHGPVA in its default configuration and, where applicable, the destinations (set up communication partners) to which data is transmitted or made accessible (e.g. network traffic analysis, log inspection, dynamic analysis tools, source-code review where available, interface enumeration, etc.);
- test setups to evaluate the data minimization mechanisms and/or configurations, including attempts to trigger or configure the SHGPVA to process additional data beyond the documented and justified items (e.g. via configuration changes, input simulations, or interface probing), based on the described mechanisms and/or configurations.

#### Assessment activities:

- the correctness and completeness of the documentation shall be verified by:
  - using the prepared methodology, identify and list all data sources (and destinations, if applicable) that are actually processed by the sample SHGPVA in its default configuration;
  - comparing the identified data sources/destinations with the documented list;

- 1024 - for every confidential data item that is documented, verifying that a clear and plausible rationale is
- 1025 provided showing that its processing is necessary for the intended purpose and reasonably foreseeable
- 1026 use;
- 1027 - verifying that no confidential data item is processed for which no documentation or no sufficient
- 1028 rationale exists;
- 1029 - reviewing the described data minimization mechanisms and/or configurations for conceptual sufficiency
- 1030 (e.g. ensure they align with best practices for limiting data to necessities, such as least-privilege data
- 1031 access or runtime checks); and
- 1032 - performing functional tests on the mechanisms and/or configurations using the prepared test setups to
- 1033 confirm they prevent or restrict processing of undocumented or unjustified data (e.g. attempt to enable
- 1034 optional data collection features and verify if they are disabled by default or require explicit justification;
- 1035 simulate inputs that could lead to extra data processing and check if they are filtered or ignored).

#### 1036 **Assignment of verdict:**

1037 The verdict PASS shall be assigned if:

- 1038 • all actually processed data sources/destinations are documented;
- 1039 • every documented data item has a sufficient rationale demonstrating necessity for the intended purpose and
- 1040 reasonably foreseeable use;
- 1041 • no undocumented or unjustified confidential data processing is observed;
- 1042 • the described mechanisms and/or configurations are conceptually sufficient to enforce data minimization; and
- 1043 • functional tests confirm that the mechanisms and/or configurations only process necessary data.

1044 Otherwise, the verdict FAIL shall be assigned.

#### 1045 **Supporting Evidence:**

- 1046 • descriptions of the performed tests and documentation of associated test records to verify the correctness and
- 1047 completeness of the documentation
- 1048 • descriptions of the performed tests and documentation of associated test records that verify the correct
- 1049 implementation of each data minimization mechanism and/or configuration

### 1050 **6.1.8 Availability protection**

#### 1051 **6.1.8.1 Assessment criteria for [AVAI-TIME-RECO-POW]**

##### 1052 **Assessment objective:**

1053 The assessment covers:

- 1054 • a functional sufficiency assessment of the recovery function interaction with each power supply used by the
- 1055 SHGPVAs MP to fulfil AVAI-TIME-RECO-POW

1056 based on the default configuration required by clause [5.1.2](#).

##### 1057 **Assessment preparation:**

1058 The following documentation for the SHGPVA shall be complete:

- 1059 • a list of all power supplies used by the SHGPVAs MP
- 1060 - for each power supply: a description whether a power supply can power the MP alone
- 1061 • a list of all functionalities of the SHGPVA that need communication involving the MP
- 1062 - for each of these functionalities:

- 1063                   ▪     a list of interfaces of the SHGPVA, where the connection status of the necessary communication  
1064                   channels can be read; OR
- 1065                   ▪     parameters of the necessary communication channel of the MP in order to externally observe if the  
1066                   connection is active
- 1067               -     a list of interfaces of the SHGPVA, where the operational status of the MP can be read
- 1068                   ▪     description how the operational status can be implied from the interface readings.

1069   The following test setups shall be prepared:

- 1070           •     the SHGPVA is set up in default configuration
- 1071           •     a test setup to:
  - 1072               -     safely disconnect or disable and reconnect or enable the power supplies of the SHGPVAs MP
  - 1073               -     enable access to at least one interfaces of the SHGPVA, where the operational status of the SHGPVA  
1074               can be read
  - 1075               -     enable access to at least one interfaces of the SHGPVA, where the connection status the necessary  
1076               communication channels status of the MP can be read
  - 1077               -     if the connection status for all necessary communication channels of the MP cannot be read from the  
1078               SHGPVA:
    - 1079                   ▪     monitor whether all necessary communication channels of the MP are active.

#### 1080   **Assessment activities:**

1081   The following activities shall be performed:

- 1082           •     for every possible order in which the MPs power supplies can be disconnected or disabled:
  - 1083               -     disconnect or disable the all power supplies of the MP
  - 1084               -     wait at least 30s
  - 1085               -     reconnect or enable the power supplies
  - 1086               -     monitor the operational status of the SHGPVA
  - 1087               -     monitor the connection status for all necessary communication channels of the MP
  - 1088               -     record the order in which the power supplies are disconnect or disable and reconnect or enable
  - 1089               -     record the time relative to the reconnection or enabling of the last power supply, after which the  
1090               SHGPVA indicates, that it is operational and all necessary communication channels are established; OR
  - 1091               -     record the time relative to the reconnection or enabling of the last power supply, after which every  
1092               necessary communication channels of the MP was active at least once, and there is no indication that the  
1093               SHGPVA has not resumed operation.

#### 1094   **Assignment of verdict:**

1095   The verdict PASS shall be assigned if:

- 1096           •     the SHGPVA signals resume of operations and establishment of all necessary communication channels within  
1097           one hour after the reconnection or enabling of the last power supply; OR
- 1098           •     all necessary communication channels of the MP were active at least once, and there is no indication that the  
1099           SHGPVA has not resumed operation within one hour
- 1100           •     The verdict FAIL shall be assigned otherwise.

#### 1101   **Supporting Evidence:**

- descriptions of the performed tests and records of performed tests.

#### 6.1.8.2 Assessment criteria for [AVAI-TIME-NETW]

##### Assessment objective:

The assessment covers:

- a conceptual assessment of AVAI-TIME-NETW
- a functional completeness assessment on the SHGPVA capabilities that are addressed by AVAI-TIME-NETW
- a functional sufficiency assessment of each time sensitive function without the need of network connectivity to operate used by the SHGPVA to fulfil AVAI-TIME-NETW

based on the default configuration required by clause [5.1.2](#).

##### Assessment preparation:

The following documentation for the SHGPVA shall be complete:

- a list of all time sensitive function of the SHGPVA
  - for each time sensitive function:
    - description of the functionalities realised or supported by this function
    - list of interfaces necessary for the operation of this function
      - for each interface:
        - communication types of the interface
- a list of interfaces of the SHGPVA, where the status of the MPs time sensitive function can be read
  - description how the status can be implied from the interface readings.

The following test setups shall be prepared:

- the SHGPVA is set up in default configuration
- a test setup to:
  - disconnect or disable the public communication of the SHGPVAs MP
  - disconnect or disable the adjacent communication of the SHGPVAs MP
  - enable access to at least one interfaces of the SHGPVA, where the status of the SHGPVAs time sensitive function can be read

##### Assessment activities:

The following activities shall be performed:

- verify the correctness and completeness of the documentation
- repeat the following steps for communication types public communication, adjacent communication and both, depending on the communication type needed by the functions to be tested:
  - disconnect or disable the corresponding communication type of the SHGPVAs MP
  - wait at least 30s
  - for each time sensitive function which does not need any interface with the corresponding communication type for its operation
    - check whether the function is in operable status

- 1138                   ▪     record the status of the function and the disconnected or disabled communication type
- 1139                   -     reconnect or enable the corresponding communication type.

#### 1140 **Assignment of verdict:**

1141 The verdict PASS shall be assigned if:

- 1142           •     no indication, that the documentation is incorrect or incomplete, are found
- 1143           •     all checked time sensitive functions are in operable state

1144 The verdict FAIL shall be assigned otherwise.

#### 1145 **Supporting Evidence:**

- 1146           •     descriptions of the performed tests and records of performed tests.

### 1147 **6.1.9     Impact minimization**

#### 1148 **6.1.10    Limit attack surface**

##### 1149 **6.1.10.1     Assessment criteria for [LAS-SBOOT]**

#### 1150 **Assessment objective:**

1151 The assessment covers:

- 1152           •     a conceptual assessment of LAS-SBOOT
  - 1153           •     a functional sufficiency assessment of the bootloader function used by the SHGPVA to fulfil LAS-SBOOT
- 1154 based on the default configuration required by clause [5.1.2](#).

#### 1155 **Assessment preparation:**

1156 The following documentation for the SHGPVA shall be complete:

- 1157           •     SBOM of the SHGPVA's hardware MP including information on which software's integrity and authenticity is
- 1158                   protected by the bootloader function
- 1159           •     documentation on how the bootloader function verifies the integrity and authenticity of the hardware MP's
- 1160                   software.

1161 The following test setup shall be prepared:

- 1162           •     a test setup for installing integrity and authenticity tampered core software, including a software package
- 1163                   including the tampered core software; or
- 1164           •     a test setup for tampering the integrity of installed core software.

#### 1165 **Assessment activities:**

- 1166           •     The SHGPVA's conformity to LAS-SBOOT shall be validated based on the documentation.
- 1167           •     The correct implementation of the bootloader function's integrity and authenticity verification of core software
- 1168                   shall be verified based on:
  - 1169               -     tampering the integrity and authenticity of installed core software or installing integrity and authenticity
  - 1170                   tampered core software; and
  - 1171               -     restarting the SHGPVA's hardware MP.

1172 **NOTE:**   Typical results are:

- 1173       • the bootloader function refuses to execute the tampered core software (and thus does not execute application  
1174       software), and
- 1175       • either halts, resets, or boots into a secure fallback and
- 1176       • an error indication is provided (e.g. via a log, an error code, an LED pattern, etc.).

1177   **Assignment of verdict:**

1178   The verdict PASS shall be assigned if:

- 1179       • the documentation indicates the SHGPVA's conformity to LAS-SBOOT; and
- 1180       • the SHGPVA's hardware MP does not execute the modified core software.

1181   Otherwise, the verdict FAIL shall be assigned.

1182   **Supporting Evidence:**

- 1183       • records of the validation of the documentation
- 1184       • descriptions of the performed tests and documentation of associated test records that verify the correct  
1185       implementation of the bootloader function's integrity and authenticity verification.

1186   **6.1.11   Logging and monitoring mechanisms**

1187   **6.1.12   Deletion mechanisms**

1188   **6.1.13   Other product's technical requirements specifications**

1189   **6.2       Assessment criteria for vulnerability handling activities**  
1190       **related to the product**

1191   The assessment criteria specified in CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3) [1] shall be met for the  
1192   SHGPVA based on the corresponding specified input and output.

1193

---

## Annex A (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

The present document has been prepared under the Commission's Standardisation request M/606 - C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table [A.1](#) confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

1206  
1207

**Table A.1: Relationship between the present document and the requirements of Regulation (EU)  
2024/2847 [i.1]**



| Harmonised Standard ETSI EN 304 631 |                                                                                                                                             |                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                            |           |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                             |                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                 | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | U/C                        | Condition |
| 1                                   | The design, development, and production of products with digital elements ensures an appropriate level of cybersecurity based on the risks. | Annex I, Part I, (1)       | [ [ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.2</a><br>[AUTHZ-LP] <a href="#">5.1.3.3</a><br>[AUTHZ-R] <a href="#">5.1.3.4</a><br>[AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a><br>[AVAI-SUM-SCHEDULE] <a href="#">5.1.7.10</a><br>[CONF-SSM] <a href="#">5.1.5.1</a><br>[CONF-COM] <a href="#">5.1.5.2</a><br>[DMIN-DJST] <a href="#">5.1.6.1</a><br>[INT-SWPCK] <a href="#">5.1.4.1</a><br>[INT-COM] <a href="#">5.1.4.2</a><br>[LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[NKEV-MKAV] <a href="#">5.1.1.1</a><br>[NKEV-SUM-SUPPORT] <a href="#">5.1.1.2</a><br>[NKEV-SUM-PROVIDE] <a href="#">5.1.1.3</a><br>[NKEV-SUM-AUTO] <a href="#">5.1.1.4</a><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a><br>[SDC-FRM] <a href="#">5.1.2.4</a><br>[USERNOT-NOSECFUC] <a href="#">5.1.12.1</a> | U                          |           |
| 2                                   | Products with digital elements are made available on the market without known exploitable vulnerabilities.                                  | Annex I, Part I, (2)(a)    | [ [NKEV-MKAV] <a href="#">5.1.1.1</a> ]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | U                          |           |

| Harmonised Standard ETSI EN 304 631 |                                                                                                                                                                                                                                                                                                                                                                                                             |                            |                                                                                                                                                                                                                                                                             |                            |           |
|-------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                                                                                                                                                                                                                                                                                             |                            |                                                                                                                                                                                                                                                                             | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                                                                                                                                                                                                                                                                                 | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                           | U/C                        | Condition |
| 3                                   | Products with digital elements are made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state.                                                                                                    | Annex I, Part I, (2)(b)    | [ [LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a><br>[SDC-FRM] <a href="#">5.1.2.4</a> ]                          | U                          |           |
| 4                                   | Products with digital elements ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them. | Annex I, Part I, (2)(c)    | [ [NKEV-SUM-SUPPORT] <a href="#">5.1.1.2</a><br>[NKEV-SUM-PROVIDE] <a href="#">5.1.1.3</a><br>[NKEV-SUM-AUTO] <a href="#">5.1.1.4</a><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a> ]    | U                          |           |
| 5                                   | Products with digital elements ensure protection from Unauthorized access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible Unauthorized access.                                                                                                                                                                | Annex I, Part I, (2)(d)    | [ [ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.2</a><br>[AUTHZ-LP] <a href="#">5.1.3.3</a><br>[AUTHZ-R] <a href="#">5.1.3.4</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a> ] | U                          |           |
| 6                                   | Products with digital elements protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means.                                                                                                                                             | Annex I, Part I, (2)(e)    | [ [CONF-SSM] <a href="#">5.1.5.1</a><br>[CONF-COM] <a href="#">5.1.5.2</a> ]                                                                                                                                                                                                | U                          |           |
| 7                                   | Products with digital elements protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorized by the user, and report on corruptions.                                                                                                                                            | Annex I, Part I, (2)(f)    | [ [INT-SWPCK] <a href="#">5.1.4.1</a><br>[INT-COM] <a href="#">5.1.4.2</a><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a> ]                                                                          | U                          |           |
| 8                                   | Products with digital elements process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimization).                                                                                                                                                                             | Annex I, Part I, (2)(g)    | [ [DMIN-DJST] <a href="#">5.1.6.1</a> ]                                                                                                                                                                                                                                     | U                          |           |

| Harmonised Standard ETSI EN 304 631 |                                                                                                                                                                                                                                                              |                            |                                                                                                                                                                                                                                                                                                                                                                                               |                            |           |
|-------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                                                                                                                                              |                            |                                                                                                                                                                                                                                                                                                                                                                                               | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                                                                                                                                  | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                                                                                                                                             | U/C                        | Condition |
| 9                                   | Products with digital elements protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.                                                    | Annex I, Part I, (2)(h)    | [ [AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a> ] | U                          |           |
| 10                                  | Products with digital elements minimize the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.                                                                         | Annex I, Part I, (2)(i)    | [ [AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a> ]                                                                                                                                                                                                                                                                                                                                               | U                          |           |
| 11                                  | Products with digital elements are designed, developed and produced to limit attack surfaces, including external interfaces.                                                                                                                                 | Annex I, Part I, (2)(j)    | [ [LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a> ]                                                                                                                                                | U                          |           |
| 12                                  | Products with digital elements are designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques.                                                                                 | Annex I, Part I, (2)(k)    | [ [AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a> ]                                                                                                                                                                                                                                              | U                          |           |
| 13                                  | Products with digital elements provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user.                  | Annex I, Part I, (2)(l)    | [ [LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[USERNOT-NOSECFUC] <a href="#">5.1.12.1</a> ]       | U                          |           |
| 14                                  | Products with digital elements provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner. | Annex I, Part I, (2)(m)    | [ [SDC-FRM] <a href="#">5.1.2.4</a> ]                                                                                                                                                                                                                                                                                                                                                         | U                          |           |
| 15                                  | Vulnerability handling requirements                                                                                                                                                                                                                          | Annex I, Part II           | clause <a href="#">5.2</a>                                                                                                                                                                                                                                                                                                                                                                    | U                          |           |

|                                          |                                                                                                                                                           |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Key to columns:</b>                   |                                                                                                                                                           |
| <b>Requirement:</b>                      |                                                                                                                                                           |
| <b>No</b>                                | A unique identifier for one row of the table which may be used to identify a requirement.                                                                 |
| <b>Description</b>                       | A textual reference to the requirement.                                                                                                                   |
| <b>Requirements of Regulation</b>        | Identification of article(s) defining the requirement in the Regulation.                                                                                  |
| <b>Clause(s) of the present document</b> | Identification of clause(s) defining the requirement in the present document unless another document is referenced explicitly.                            |
|                                          |                                                                                                                                                           |
| <b>Requirement Conditionality</b>        |                                                                                                                                                           |
| <b>U/C</b>                               | Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the manufacturer's claimed functionality of the equipment (C). |
| <b>Condition</b>                         | Explains the conditions when the requirement is or is not applicable for a requirement which is classified "conditional".                                 |

1208

1209 Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list  
 1210 published in the Official Journal of the European Union. Users of the present document should consult frequently the  
 1211 latest list published in the Official Journal of the European Union.

1212 Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

1213

## Annex B (informative): Guidance for the application of the present document

The following approach can be used (e.g. by manufacturers)

- to develop products that are compliant the present document; or
- to analyze the compliance of a product to the present document.

The approach is constructed such that it uses parts of an assessment of cybersecurity risks and can be integrated into the management of cybersecurity risks.

- Step 1 - check if the product is in scope of the present document provided in clause [1](#) by:
  - verifying that the product is a SHGPVA as specified within the "technical description" of the "category of product" number "16." by Regulation (EU) 2025/2392 [i.2]; and
  - identifying the product context by:
    - identifying the product's architectural components; and
    - identifying all data processed by the product (data assets); and
    - identifying all functions provided by the product (function assets); and
    - identifying the architectural components' operational environments; and
    - identifying the architectural components' interfaces and communication types; and
  - verifying that the product is covered within the product context described in clause [4](#) by:
    - verifying that the architectural components of the product are covered within the product architecture described in clause [4.2](#); and
    - verifying that the data processed by the product and the functions provided by the product are covered within clause [4.1](#); and
    - verifying that the architectural components' operational environments are covered within clause [4.3](#); and
    - verifying that the architectural components' interfaces and communication types are covered within clause [4.4](#).

NOTE: The identification of the items mentioned above can be reused for assessing the compliance of the product with the requirements in clause [5](#).

NOTE: If a product is a SHGPVA as specified by Regulation (EU) 2025/2392 [i.2] but is not covered within the product context described in clause [4](#), it is assumed that the product is not or not completely covered by the present document. In such cases informing ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR) via the [Committee Support Staff](#) might help to address those products in potential revisions of the present document.

- Step 2 - identify information to determine risk factors by:
  - identifying for each function provided by the product:
    - its impact classes according to clause [D.3](#); and
    - the architectural components that perform the function; and
    - the communication types and the interfaces that can receive corresponding function trigger input; and
  - identifying for each data processed by the product:

- 1253           ▪     its impact classes according to clause [D.2](#)
- 1254           ▪     the architectural components that persistently store the data; and
- 1255           ▪     the architectural components that can communicate the data; and
- 1256           ▪     the communication types and the interfaces over which the data is communicated.

1257           NOTE: If data processed by the product or functions provided by the product are not covered  
 1258           within clause [4.1](#), clause [C.1](#) can be used to identify impact classes for function and data assets that  
 1259           are outside the scope of the present document.

- 1260           •     Step 3 - identify concrete requirements for and specific security measures/mitigations of the product that  
 1261           satisfy those requirements by:

1262           -     for each requirement in clause [5](#):

- 1263           ▪     identifying the requirements applicability by evaluating the requirement's potential preconditions  
 1264           and exceptions based on the product's properties; and
- 1265           ▪     (for requirements that include assignment tables) identifying the required protection mechanisms'  
 1266           strengths (specified in annex [E](#)) by evaluating the requirement's assignment table based on the  
 1267           product's properties determining the attack surface and impact parameters; and
- 1268           ▪     identifying the specific security measures/mitigations that satisfy the requirement.

1269           NOTE: An assignment table can yield multiple mechanisms' strengths from different  
 1270           circumstances, which all have to be satisfied.

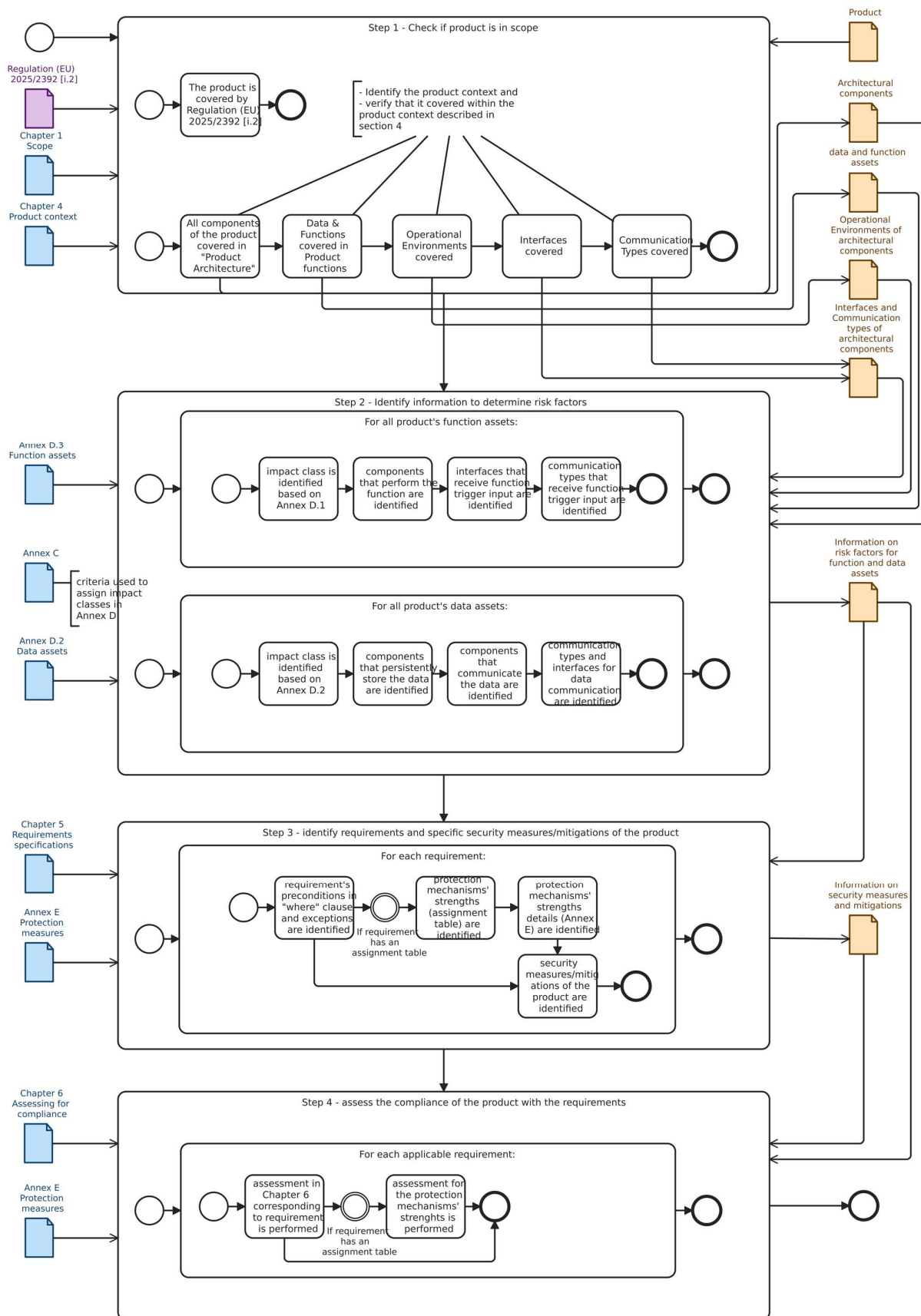
1271           EXAMPLE: Authentication requirements prior to changes of a SHGPVAs configuration are different  
 1272           whether the changes can be made via a web GUI, accessible from adjacent or public networks, a GUI,  
 1273           accessible from the SHGPVAs touchscreen, or a console, accessible be connecting to a serial port. All  
 1274           of this cases can be simultaneously present on the same SHGPVA.

- 1275           •     Step 4 - assess the compliance of the product with the requirements in clause [5](#) by:

1276           -     for each requirement in clause [5](#), performing the corresponding assessment for compliance described in  
 1277           clause [6](#) (the functional sufficiency assessments for different protection measures strengths are specified  
 1278           in annex [E](#)) by:

- 1279           ▪     preparing the assessment for the product; and
- 1280           ▪     performing the assessment activities for the product; and
- 1281           ▪     assigning an assessment verdict for the product; and
- 1282           ▪     generating the supporting evidences for the assessment.

1283           The figure [B.1](#) provides a graphical representation of the guidance for the application of the present document.



**Figure B.1: Graphical representation on guidance for the application of the present document**

---

## Annex C (informative): Information on the methodology for the assessment of cybersecurity risks used to develop the present document

This informative annex is intended to provide information on the methodology for the assessment of cybersecurity risks used to develop the present document.

---

### C.1 Guidance for determining impact classes

#### C.1.1 General

The present document uses the following criteria to determine the impact classes of different specific SHGPVA assets provided in annex D.

#### C.1.2 confidential data

##### **confidentiality impact class low (IMP.CONF.Low):**

The disclosure may lead to:

- inconvenient consequences on the consumer(s); or
- additional or increased attack opportunities over a short time and limited to communication types not higher than local on the SHGPVA.

##### **confidentiality impact class medium (IMP.CONF.Medium):**

The disclosure may lead to:

- serious impact on the consumer(s);
- additional or increased attack opportunities over a short time on the SHGPVA or a limited number of other products; or
- additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the SHGPVA.

##### **confidentiality impact class high (IMP.CONF.High):**

The disclosure may lead to:

- significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- additional or increased attack opportunities over a prolonged time on the SHGPVA or a limited number of other products; or
- additional or increased attack opportunities over a short time on a significant number of other products.

#### C.1.3 loss sensitive data

##### **loss sensitive availability impact class low (IMP.AVALLOSS.Low):**

The loss may lead to:

- inconvenient consequences on the consumer(s); or
- non-availability of non-key-functionalities on the SHGPVA for a short time.



1319 **loss sensitive availability impact class medium (IMP.AVALOSS.Medium):**

1320 The loss may lead to:

- 1321 • serious impact on the consumer(s); or
- 1322 • non-availability of key-functionalities of the SHGPVA over a short time; or
- 1323 • non-availability of non-key-functionalities on the SHGPVA for a prolonged time.

1324 **loss sensitive availability impact class high (IMP.AVALOSS.High):**

1325 The loss may lead to:

- 1326 • significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- 1327 • non-availability of key-functionalities of the SHGPVA for a prolonged time; or
- 1328 • permanent non-availability of non-key-functionalities of the SHGPVA.

## 1329 C.1.4 time sensitive data and time sensitive function

1330 **time sensitive availability impact class low (IMP.AVAL.TIME.Low):**

1331 The delay of availability may lead to:

- 1332 • non-availability of non-key-functionalities on the SHGPVA for a short time.

1333 **time sensitive availability impact class medium (IMP.AVAL.TIME.Medium):**

1334 The delay of availability may lead to:

- 1335 • non-availability of key-functionalities on the SHGPVA for a short time; or
- 1336 • non-availability of non-key-functionalities on the SHGPVA for a prolonged time.

1337 **time sensitive availability impact class high (IMP.AVAL.TIME.High):**

1338 The delay of availability may lead to:

- 1339 • non-availability of key-functionalities of the SHGPVA for a prolonged time; or
- 1340 • permanent non-availability of non-key-functionalities of the SHGPVA.

## 1341 C.1.5 integrity relevant data and integrity relevant function

1342 **integrity impact class low (IMP.INT.Low):**

1343 The tampering may lead to:

- 1344 • inconvenient consequences on the consumer(s);
- 1345 • additional or increased attack opportunities for a short time and limited to communication types not higher  
1346 than local on the SHGPVA; or
- 1347 • non-availability of non-key-functionalities on the SHGPVA for a short time.

1348 **integrity impact class medium (IMP.INT.Medium):**

1349 The tampering may lead to:

- 1350 • serious impact on the consumer(s);
- 1351 • additional or increased attack opportunities over a short time on the SHGPVA or a limited number of other  
1352 products;

- 1353 • additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the
- 1354 SHGPVA; or
- 1355 • non-availability of key-functionalities on the SHGPVA for a short time; or
- 1356 • non-availability of non-key-functionalities on the SHGPVA for a prolonged time.
- 1357 **integrity impact class high (IMP.INT.High):**
- 1358 The tampering may lead to:
- 1359 • significant or even irreversible impact on the consumer(s) (e.g. personal or financial harm);
- 1360 • additional or increased attack opportunities for a prolonged time on the SHGPVA or a limited number of other
- 1361 products;
- 1362 • additional or increased attack opportunities for a short time on a significant number of other products;
- 1363 • non-availability of key-functionalities of the SHGPVA for a prolonged time; or
- 1364 • permanent non-availability of non-key-functionalities of the SHGPVA.

---

1365 **Annex D (normative):**

1366 **Relationship between specific data and functions assets**

1367 **covered by the present document to impact classes for**

1368 **generic asset categories**

## 1369 **D.1 Identifier**

1370 The following identifier for impact classes apply:

- 1371 **IMP:** impact class
- 1372 **IMP.Low:** impact class low
- 1373 **IMP.Medium:** impact class medium
- 1374 **IMP.High:** impact class high
- 1375 **IMP.CONF:** confidentiality impact class
- 1376 **IMP.CONF.Low:** confidentiality impact class low
- 1377 **IMP.CONF.Medium:** confidentiality impact class medium
- 1378 **IMP.CONF.High:** confidentiality impact class high
- 1379 **IMP.INT:** integrity impact class
- 1380 **IMP.INT.Low:** integrity impact class low
- 1381 **IMP.INT.Medium:** integrity impact class medium
- 1382 **IMP.INT.High:** integrity impact class high
- 1383 **IMP.AVAL.TIME:** time sensitive availability impact class
- 1384 **IMP.AVAL.TIME.Low:** time sensitive availability impact class low
- 1385 **IMP.AVAL.TIME.Medium:** time sensitive availability impact class medium

- 1386 **IMP.AVAL.TIME.High**: time sensitive availability impact class high
- 1387 **IMP.AVAL.LOSS**: loss sensitive availability impact class
- 1388 **IMP.AVAL.LOSS.Low**: loss sensitive availability impact class low
- 1389 **IMP.AVAL.LOSS.Medium**: loss sensitive availability impact class medium
- 1390 **IMP.AVAL.LOSS.High**: loss sensitive availability impact class high
- 1391 **IMP.FH**: impact class for function, whose use can cause harm
- 1392 **IMP.FH.Low**: function, whose use can cause harm impact class low
- 1393 **IMP.FH.Medium**: function, whose use can cause harm impact class medium
- 1394 **IMP.FH.High**: function, whose use can cause harm impact class high
- 1395 **IMP.FH.SP**: function, whose use can impact the safety or privacy of human entities impact class
- 1396 **IMP.FH.SP.Low**: function, whose use can impact the safety or privacy of human entities impact class low
- 1397 **IMP.FH.SP.Medium**: function, whose use can impact the safety or privacy of human entities impact class medium
- 1398 **IMP.FH.SP.High**: function, whose use can impact the safety or privacy of human entities impact class high
- 1399 **IMP.FH.DSN**: function, whose use can impact the availability of other devices, services or networks impact class
- 1400 **IMP.FH.DSN.Low**: function, whose use can impact the availability of other devices, services or networks impact class  
1401 low
- 1402 **IMP.FH.DSN.Medium**: function, whose use can impact the availability of other devices, services or networks impact  
1403 class medium
- 1404 **IMP.FH.DSN.High**: function, whose use can impact the availability of other devices, services or networks impact class  
1405 high
- 1406 **IMP.FH.CCON**: function, which can communicate confidential data impact class
- 1407 **IMP.FH.CCON.Low**: function, which can communicate confidential data impact class low
- 1408 **IMP.FH.CCON.Medium**: function, which can communicate confidential data impact class medium
- 1409 **IMP.FH.CCON.High**: function, which can communicate confidential data impact class high
- 1410 **IMP.FH.MINT**: function, which can modify integrity relevant data impact class
- 1411 **IMP.FH.MINT.Low**: function, which can modify integrity relevant data impact class low
- 1412 **IMP.FH.MINT.Medium**: function, which can modify integrity relevant data impact class medium
- 1413 **IMP.FH.MINT.High**: function, which can modify integrity relevant data impact class high

## D.2 Data assets

Table D.1: Mapping of specific data assets to impact classes for generic data asset categories

| specific data asset       | impact class for data asset categories                                 |                                                                           |                                                                  |                                                                  |
|---------------------------|------------------------------------------------------------------------|---------------------------------------------------------------------------|------------------------------------------------------------------|------------------------------------------------------------------|
|                           | impact class for confidential SHGPVA data                              | impact class for integrity relevant SHGPVA data                           | impact class for time critical availability relevant SHGPVA data | impact class for loss critical availability relevant SHGPVA data |
| public data asset         | IMP.CONF.Low                                                           | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | no                                                               |
| personal calendar data    | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| personal notes data       | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| personal contact data     | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| health data               | IMP.CONF.High                                                          | IMP.INT.High                                                              | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| activity data             | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| device location data      | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Low                                                |
| audio input data          | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | no                                                               |
| video input data          | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Low                                                | no                                                               |
| network status data       | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Medium                                             | IMP.AVAI.LOSS.Low                                                |
| authorization policy data | IMP.CONF.Medium                                                        | IMP.INT.High                                                              | IMP.AVAI.TIME.Medium                                             | IMP.AVAI.LOSS.Low                                                |
| SHGPVA state data         | IMP.CONF.Medium                                                        | IMP.INT.Medium                                                            | IMP.AVAI.TIME.Medium                                             | IMP.AVAI.LOSS.Low                                                |
| logging data              | IMP.CONF = IMP.CONF of confidential data contained in the logging data | IMP.INT = Highest /IncludeIDE{ImpactClasses:FunctionWhoseUseCanCauseHarm} | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| software package          | IMP.CONF = IMP.CONF of confidential data contained in the package      | IMP.INT = Highest IMP.INT of SHGPVA's integrity relevant function         | no                                                               | no                                                               |

## D.3 Function assets

Table D.2: Mapping of specific function assets to impact classes for generic function asset categories

| specific function asset                           | impact class for function asset categories                 |                                                    |                                                              |
|---------------------------------------------------|------------------------------------------------------------|----------------------------------------------------|--------------------------------------------------------------|
|                                                   | impact class for integrity relevant function               | impact class for time sensitive function           | impact class for function, whose use can cause harm          |
| audio input function                              | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| video input function                              | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| audio output function                             | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| video output function                             | IMP.INT.Medium                                             | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| SHGPVA function which can communicate SHGPVA data | IMP.INT = Maximum (IMP.CONF, IMP.INT) of communicated data | IMP.AVAI.TIME = IMP.AVAI.TIME of communicated data | IMP.FH = Maximum (IMP.FH.Low, IMP.CONF of communicated data) |
| connection function                               | IMP.INT.Low                                                | IMP.AVAI.TIME.Low                                  | IMP.FH.Medium                                                |
| SHGPVA function which can modify SHGPVA data      | IMP.INT = IMP.INT of modified data                         | no                                                 | IMP.FH = IMP.INT of modified data                            |

### D.3.1 functions whose use can cause harm

The contents of the column *impact class for function, whose use can cause harm* of table [D.2](#) are split into details in table [D.3](#).

**Table D.3: Mapping of specific function assets to impact classes for different aspects of function, whose use can cause harm**

| specific function asset                           | impact class for function asset categories                                              |                                                                                                         |                                                                    |                                                                     |                                                              |
|---------------------------------------------------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|---------------------------------------------------------------------|--------------------------------------------------------------|
|                                                   | impact class for function, whose use can impact the safety or privacy of human entities | impact class for function, whose use can impact the availability of other devices, services or networks | impact class for function, which can communicate confidential data | impact class for function, which can modify integrity relevant data | impact class for function, whose use can cause harm          |
| audio input function                              | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| video input function                              | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| audio output function                             | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| video output function                             | IMP.FH.SP.Medium                                                                        | no                                                                                                      | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| SHGPVA function which can communicate SHGPVA data | no                                                                                      | IMP.FH.DSN.Low                                                                                          | IMP.FH.CCON = IMP.CONF of communicated data                        | no                                                                  | IMP.FH = Maximum (IMP.FH.Low, IMP.CONF of communicated data) |
| connection function                               | no                                                                                      | IMP.FH.DSN.Medium                                                                                       | no                                                                 | no                                                                  | IMP.FH.Medium                                                |
| SHGPVA function which can modify SHGPVA data      | no                                                                                      | no                                                                                                      | no                                                                 | IMP.FH.MINT = IMP.INT of modified data                              | IMP.FH = IMP.INT of modified data                            |

---

## Annex E (normative): Protection measures

### E.1 Identifier

The following identifier apply here and in the assignment tables in clause 5:

**N/A:** not applicable

**AUTH.Basic:** authentication strength level basic

**AUTH.Normal:** authentication strength level normal

**AUTH.Enhanced:** authentication strength level enhanced

**AUTH.Strong:** authentication strength level strong

**CONF.COM.Basic:** communication of confidential data protection strength level basic

**CONF.COM.Normal:** communication of confidential data protection strength level normal

**CONF.COM.Enhanced:** communication of confidential data protection strength level enhanced

**CONF.COM.Strong:** communication of confidential data protection strength level strong

**INT.COM.Basic:** communication of integrity relevant data protection strength level basic

**INT.COM.Normal:** communication of integrity relevant data protection strength level normal

**INT.COM.Enhanced:** communication of integrity relevant data protection strength level enhanced

**INT.COM.Strong:** communication of integrity relevant data protection strength level strong

**CONF.SSM.Basic:** confidential persistent storage strength level basic

**CONF.SSM.Normal:** confidential persistent storage strength level normal

**CONF.SSM.Enhanced:** confidential persistent storage strength level enhanced

**CONF.SSM.Strong:** confidential persistent storage strength level strong

**SAN.Normal:** input sanitization of input strength level normal

**SAN.Strong:** input sanitization of input strength level strong

**AUT.VER.Enhanced:** authenticity verification strength level enhanced

**AUT.VER.Strong:** authenticity verification strength level strong

**INT.SW.VER.Basic:** software package integrity verification strength level basic

**INT.SW.VER.Normal:** software package integrity verification strength level normal

**INT.SW.VER.Enhanced:** software package integrity verification strength level enhanced

**INT.SW.VER.Strong:** software package integrity verification strength level strong

**INT.VER.Basic:** integrity verification strength level basic

**INT.VER.Normal:** integrity verification strength level normal

**INT.VER.Enhanced:** integrity verification strength level enhanced

**INT.VER.Strong:** integrity verification strength level strong

---

## E.2 access control mechanism's strength

## E.3 authentication mechanism strength

### E.3.1 AUM-FH Authentication for functions whose use can cause harm

#### E.3.1.1 General

The present document specifies the strength of authentication mechanisms by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

#### E.3.1.2 authentication strength level basic

The authentication strength level basic shall protect against the following attack types:

**limited presentation attack:** Opportunistic presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using authentication factors of another entity

**limited brute force attack:** Opportunistic guessing attacks on authentication mechanisms based on authentication factors of the type knowledge, by guessing manually without the use of technical aids.

#### E.3.1.3 authentication strength level normal

The authentication strength level normal shall protect against the following attack types:

**automated brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical.

**presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using medium effort methods like e.g. photos, cut out masks, audio replays, video replays, AI generated voices

**automated security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from other uses or self-created, without using any specific knowledge of the targeted authentication mechanisms.

**replay attack:** An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

**person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

#### E.3.1.4 authentication strength level enhanced

The authentication strength level enhanced shall protect against the following attack types:

**targeted presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type inherence, using enhanced effort methods like e.g. (partial) silicone masks, layered prints

**targeted brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information.

**targeted security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from devices of the same type as the SHGPVA or self-created, using specific knowledge of the targeted authentication mechanisms and the SHGPVA.

**replay attack:** An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

**person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

### E.3.1.5 authentication strength level strong

The authentication strength level strong shall protect against the following attack types:

**elaborate presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type inheritance", using high effort methods like e.g. highly realistic silicone or latex masks, limb replicas, trained deepfakes.

**elaborate brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information, and unrestricted duration.

**elaborate security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors created or sourced from devices of the same type as the SHGPVA and modified, specifically for the targeted authentication mechanisms.

**replay attack:** An attacker intercepts valid data transmissions and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

**person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

## E.3.2 Assessment for authentication mechanism strength

### E.3.2.1 Assessment criteria regarding the protection against limited presentation attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use authentication factors of the type inheritance against limited presentation attacks.

#### Assessment preparation:

- the SHGPVA shall be set up in default configuration
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created
- at least one interface, where the authentication mechanism is reachable shall be documented

#### Assessment activities:

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and authentication factors, not belonging to the person who set up the account, for at least five times or ten minutes at highest archivable query frequency
- the outcome and used authentication factor of each attempt shall be recorded



**Assignment of verdict:**

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- description of the performed test
- all test records of the performed test

### E.3.2.2 Assessment criteria regarding the protection against targeted presentation attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide a enhanced level of protection and use authentication factors of the type inherence against targeted presentation attacks.

**Assessment preparation:**

- the SHGPVA shall be set up in default configuration
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created
- at least one interface, where the authentication mechanism is reachable shall be documented
- authentication factors shall be fabricated using common materials and tools as well as readily available source materials. The fabrication process shall not be longer than *one workday* per authentication factor.

**Assessment activities:**

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least five times with slightly different parameters each
- the outcome and used authentication factor of each attempt shall be recorded

**Assignment of verdict:**

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

**Supporting Evidence:**

- description of the performed test
- all test records of the performed test

### E.3.2.3 Assessment criteria regarding the protection against elaborate presentation attacks

**Assessment objective:**

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type inherence against elaborate presentation attacks.

**Assessment preparation:**

- the SHGPVA shall be set up in default configuration

- 1575 • a genuine enrolled biometric template in the corresponding authentication mechanism with credential for
- 1576 authentication shall be created
- 1577 • at least one interface, where the authentication mechanism is reachable shall be documented
- 1578 • authentication factors shall be fabricated using specialized materials and tools as well as cumbersome
- 1579 extracted source materials. The duration of the fabrication process per authentication factor is not restricted.

#### 1580 **Assessment activities:**

- 1581 • authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine
- 1582 enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least
- 1583 five times with slightly different parameters each
- 1584 • the outcome and used authentication factor of each attempt shall be recorded.

#### 1585 **Assignment of verdict:**

1586 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1587 The verdict FAIL shall be assigned otherwise.

#### 1588 **Supporting Evidence:**

- 1589 • description of the performed test
- 1590 • all test records of the performed test

### 1591 **E.3.2.4 Assessment criteria regarding the protection against limited brute**

### 1592 **force attacks**

#### 1593 **Assessment objective:**

1594 The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use

1595 authentication factors of the type knowledge against limited brute force attacks.

#### 1596 **Assessment preparation:**

- 1597 • the SHGPVA shall be set up in default configuration
- 1598 • at least one interface, where the authentication mechanism is reachable shall be documented

1599 the security insurance time ( $T_{SI}$ ) for this assessment is 10 minutes (600s).

#### 1600 **Assessment activities:**

1601 the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.

1602  $C_{PW,min} = (10)^6$  for a 6-digit PIN or  $C_{PW,min} = \frac{9!}{(9-5)!}$  for a pattern of 5 nonrecurring nodes in a field of 9 notes

1603 the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $f_{LA,max} = \frac{5}{5*3s+3600s}$  for 3 seconds

1604 per login attempt + a one-hour waiting period after 5 failed login attempts

1605 the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be

1606 calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- 1607 • the methods and outcome of each step shall be recorded.

#### 1608 **Assignment of verdict:**

1609 The verdict PASS shall be assigned if the calculated probability  $p_{GRP}$  is less than  $10^{-2}$ .

1610 The verdict FAIL shall be assigned otherwise.

#### 1611 **Supporting Evidence:**

- 1612 • the authentication mechanism and the interface via which it was accessed
- 1613 • all test records of the performed test.

### 1614 E.3.2.5 Assessment criteria regarding the protection against targeted brute 1615 force attacks

#### 1616 **Assessment objective:**

1617 The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and  
1618 use authentication factors of the type knowledge against targeted brute force attacks.

#### 1619 **Assessment preparation:**

- 1620 • the SHGPVA shall be set up in default configuration
- 1621 • at least one interface, where the authentication mechanism is reachable shall be documented

1622 the security insurance time ( $T_{SI}$ ) for this assessment one month ( $2,6 * 10^6s$ ).

#### 1623 **Assessment activities:**

1624 the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.,  
1625  $C_{PW,min} = (26 * 2 + 10)^8$  for minimum 8 characters of upper-case or lower-case letters or numbers

1626 the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $f_{LA,max} = (0,1s)^{-1}$  for 10 login  
1627 attempt per second

1628 the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be  
1629 calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- 1630 • the methods and outcome of each step shall be recorded.

#### 1631 **Assignment of verdict:**

1632 The verdict PASS shall be assigned if the calculated probability  $p_{GRP}$  is less than  $10^{-6}$ .

1633 The verdict FAIL shall be assigned otherwise.

#### 1634 **Supporting Evidence:**

- 1635 • the authentication mechanism and the interface via which it was accessed
- 1636 • all test records of the performed test.

### 1637 E.3.2.6 Assessment criteria regarding the protection against automated 1638 brute force attacks

#### 1639 **Assessment objective:**

1640 The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and  
1641 use authentication factors of the type knowledge against targeted brute force attacks.

#### 1642 **Assessment preparation:**

- 1643 • the SHGPVA shall be set up in default configuration
- 1644 • at least one interface, where the authentication mechanism is reachable shall be documented

1645 the security insurance time ( $T_{SI}$ ) for this assessment is one day (86400s).

#### 1646 **Assessment activities:**

1647 the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.  
 1648  $C_{PW,min} = (26 * 2 + 10)^8$  for minimum 8 characters of upper-case case or lower-case letters or numbers

1649 the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $f_{LA,max} = \frac{5}{5*3s+3600s}$  for 3 seconds  
 1650 per login attempt + a one-hour waiting period after 5 failed login attempts

1651 the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be  
 1652 calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- 1653 • the methods and outcome of each step shall be recorded.

#### 1654 **Assignment of verdict:**

1655 The verdict PASS shall be assigned if the calculated probability  $p_{GRP}$  is less than  $10^{-6}$ .

1656 The verdict FAIL shall be assigned otherwise.

#### 1657 **Supporting Evidence:**

- 1658 • the authentication mechanism and the interface via which it was accessed
- 1659 • all test records of the performed test.

### 1660 **E.3.2.7 Assessment criteria regarding the protection against presentation** 1661 **attacks**

#### 1662 **Assessment objective:**

1663 The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and  
 1664 use authentication factors of the type inherence against presentation attacks.

#### 1665 **Assessment preparation:**

- 1666 • the SHGPVA shall be set up in default configuration
- 1667 • a genuine enrolled biometric template in the corresponding authentication mechanism with credential for  
 1668 authentication shall be created
- 1669 • at least one interface, where the authentication mechanism is reachable shall be documented
- 1670 • authentication factors shall be fabricated using readily available materials and tools as well as readily available  
 1671 source materials. The fabrication process shall not be longer than *twenty* minutes per authentication factor.

1672 NOTE: Readily available source materials are e.g. fingerprints on everyday items or publicly available photos.  
 1673 Readily available materials and tools are of adhesive tape, printer paper, common printers.

#### 1674 **Assessment activities:**

- 1675 • authentication at the created account shall be attempted using the correct account name, if present, and at least  
 1676 two fabricated authentication factors tried at least five times with slightly different parameters each
- 1677 • the outcome and used fabricated authentication factor of each attempt shall be recorded.

#### 1678 **Assignment of verdict:**

1679 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1680 The verdict FAIL shall be assigned otherwise.

#### 1681 **Supporting Evidence:**

- 1682 • description of the performed test
- 1683 • all test records of the performed test.

### E.3.2.8 Assessment criteria regarding the protection against elaborate brute force attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

#### Assessment preparation:

- the SHGPVA shall be set up in default configuration
- at least one interface, where the authentication mechanism is reachable shall be documented

the security insurance time ( $T_{SI}$ ) for this assessment is five years ( $1,6 * 10^8 s$ ).

#### Assessment activities:

the minimal recommended complexity of passwords accepted by the mechanism ( $C_{PW,min}$ ) shall be determined; e.g.  $(26 * 2 + 10)^8$  for minimum 8 characters of upper-case case or lower-case letters or numbers

the maximum sustained login attempt frequency ( $f_{LA,max}$ ) shall be determined; e.g.  $(0,1s)^{-1}$  for 10 login attempt per second

the probability of guessing a completely random password of the minimal recommended complexity ( $p_{GRP}$ ) shall be calculated by  $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$

- the methods and outcome of each step shall be recorded.

#### Assignment of verdict:

The verdict PASS shall be assigned if the calculated probability is less than  $10^{-6}$ .

The verdict FAIL shall be assigned otherwise.

#### Supporting Evidence:

- the authentication mechanism and the interface via which it was accessed
- all test records of the performed test.

### E.3.2.9 Assessment criteria regarding the protection against automated security token spoofing attacks

#### Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type possession against automated security token spoofing attacks.

#### Assessment preparation:

- the SHGPVA shall be set up in default configuration
- an account in the corresponding authentication mechanism with a security token for authentication shall be created
- at least one interface, where the authentication mechanism is reachable shall be documented
- security tokens, that match specifications of the interfaces, via which the authentication mechanism is reachable, shall be prepared or created without using any specific knowledge of the authentication mechanism.

#### Assessment activities:

1720       • authentication at the created account shall be attempted using the correct account name, if present, and the  
1721       prepared or created security tokens

1722       • the outcome and used authentication factor of each attempt shall be recorded

1723 **Assignment of verdict:**

1724 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used  
1725 authentication factor exactly matches the configured one.

1726 The verdict FAIL shall be assigned otherwise.

1727 **Supporting Evidence:**

1728       • description of the performed test

1729       • all test records of the performed test.

1730 **E.3.2.10 Assessment criteria regarding the protection against targeted**  
1731 **security token spoofing attacks**

1732 **Assessment objective:**

1733 The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and  
1734 use authentication factors of the type possession against targeted security token spoofing attacks.

1735 **Assessment preparation:**

1736       • the SHGPVA shall be set up in default configuration

1737       • an account in the corresponding authentication mechanism with a security token for authentication shall be  
1738       created

1739       • at least one interface, where the authentication mechanism is reachable shall be documented

1740       • security tokens, shall be prepared or created, which match the specifications of the authentication mechanism.

1741 **Assessment activities:**

1742       • authentication at the created account shall be attempted using the correct account name, if present, and the  
1743       prepared or created security tokens

1744       • the outcome and used authentication factor of each attempt shall be recorded.

1745 **Assignment of verdict:**

1746 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used  
1747 authentication factor exactly matches the configured one.

1748 The verdict FAIL shall be assigned otherwise.

1749 **Supporting Evidence:**

1750       • description of the performed test

1751       • all test records of the performed test.

1752 **E.3.2.11 Assessment criteria regarding the protection against elaborate**  
1753 **security token spoofing attacks**

1754 **Assessment objective:**

1755 The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use  
1756 authentication factors of the type possession against elaborate security token spoofing attacks.

1757 **Assessment preparation:**

- 1758 • the SHGPVA shall be set up in default configuration
- 1759 • an account in the corresponding authentication mechanism with a security token for authentication shall be  
1760 created
- 1761 • at least one interface, where the authentication mechanism is reachable shall be documented
- 1762 • security tokens, shall be prepared or created, which match the specifications of the authentication mechanism  
1763 and use information extracted from the original security token.

1764 **Assessment activities:**

- 1765 • authentication at the created account shall be attempted using the correct account name, if present, and the  
1766 prepared or created security tokens
- 1767 • the outcome and used authentication factor of each attempt shall be recorded.

1768 **Assignment of verdict:**

1769 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used  
1770 authentication factor exactly matches the configured one.

1771 The verdict FAIL shall be assigned otherwise.

1772 **Supporting Evidence:**

- 1773 • description of the performed test
- 1774 • all test records of the performed test.

### 1775 E.3.2.12 Assessment criteria regarding the protection against replay attacks

1776 **Assessment objective:**

1777 The assessment covers functional testing of authentication mechanisms that use authentication factors of the type  
1778 knowledge or possession (e.g. a session token) against replay attacks.

1779 **Assessment preparation:**

- 1780 • the SHGPVA shall be set up in default configuration
- 1781 • the authentication mechanism shall be active
- 1782 • a communication partner with active authentication mechanisms shall be set up for the SHGPVA
- 1783 • a capture and replay tool between SHGPVA and its communication partner shall be set up
- 1784 • at least one interface, where the authentication mechanism is reachable shall be documented.

1785 **Assessment activities:**

- 1786 • Initiate a connection between the SHGPVA and its communication partner.
- 1787 • Use a capture tool to record the transmitted message or transaction data.
- 1788 • Replay (retransmit) the captured message to the product using a suitable tool in place to mimic the original  
1789 communication partner.
- 1790 • Record if the product accepts the retransmitted data.

1791 **Assignment of verdict:**

1792 The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1793 The verdict FAIL shall be assigned otherwise.

1794 **Supporting Evidence:**

- 1795 • description of the performed test
- 1796 • all test records of the performed test.

1797 **E.3.2.13 Assessment criteria regarding the protection against PitM attacks**

1798 **Assessment objective:**

1799 The assessment covers functional testing of authentication mechanisms that use authentication factors of the type  
1800 knowledge or possession (e.g. a session token) against PitM attacks.

1801 **Assessment preparation:**

- 1802 • the SHGPVA shall be set up in default configuration
- 1803 • the authentication mechanism shall be active
- 1804 • a communication partner with active authentication mechanisms shall be set up for the SHGPVA
- 1805 • a capture and PitM tool between SHGPVA and its communication partner shall be set up
- 1806 • at least one interface, where the authentication mechanism is reachable shall be documented.

1807 **Assessment activities:**

- 1808 • Initiate a connection between the SHGPVA and its communication partner.
- 1809 • Attempt to capture data (consumer credentials, tokens, etc.) with the tool in place and actively intercept  
1810 communication to impersonate the communication partner during:
  - 1811 - generation and communication of authentication factors for the communication partner (if not  
1812 pre-configured); and
  - 1813 - authentication of the communication partner
- 1814 • Record if the impersonation as communication partner is successful.

1815 **Assignment of verdict:**

1816 The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1817 The verdict FAIL shall be assigned otherwise.

1818 **Supporting Evidence:**

- 1819 • description of the performed test
- 1820 • all test records of the performed test.



---

## E.4 confidentiality protection strength

### E.4.1 CONF-SSM Confidentiality protecting persistent storage for confidential data

#### E.4.1.1 General

The present document specifies confidentiality protecting secure storage mechanisms' strength, by certain security properties. Those properties are constructed such that mechanisms of higher strength have the properties of lower strength mechanisms.

#### E.4.1.2 confidential persistent storage strength level basic

Mechanisms for the confidential persistent storage strength level basic shall encrypt such that decryption is only possible for the SHGPVA.

#### E.4.1.3 confidential persistent storage strength level normal

Mechanisms for the confidential persistent storage strength level normal shall encrypt such that decryption is

- only possible for the SHGPVA and
- only performed after a successful authentication.

#### E.4.1.4 confidential persistent storage strength level enhanced

Mechanisms for the confidential persistent storage strength level enhanced shall encrypt supported by hardware, such that

- decryption is only possible for the SHGPVA after a successful authentication and
- the extraction of the encryption key is prevented by hardware.

#### E.4.1.5 confidential persistent storage strength level strong

Mechanisms for the confidential persistent storage strength level strong shall prevent the extraction of data by hardware.

---

## E.5 confidentiality protection strength

### E.5.1 CONF-COM Communication of confidential data

#### E.5.1.1 General

The present document specifies the strength of mechanisms to protect the confidentiality of communicated confidential data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

#### E.5.1.2 communication of confidential data protection strength level basic

The communication of confidential data protection strength level basic shall protect against the following attack types:

**eavesdropping:** An attacker secretly intercepts the communication between the SHGPVA and another entity or another part of the SHGPVA.

### E.5.1.3 communication of confidential data protection strength level normal

The communication of confidential data protection strength level normal shall protect against the following attack types:

**eavesdropping:** An attacker secretly intercepts the communication between the SHGPVA and another entity or another part of the SHGPVA.

**direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

**downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

### E.5.1.4 communication of confidential data protection strength level enhanced

The communication of confidential data protection strength level enhanced shall protect against the following attack types:

**eavesdropping:** An attacker secretly intercepts the communication between the SHGPVA and another entity or another part of the SHGPVA.

**person in the middle attack:** An attacker secretly alters the communication between the SHGPVA and another entity or another part of the SHGPVA to gain a trusted relationship with the involved communication partners without their knowledge.

**direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

**downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

### E.5.1.5 communication of confidential data protection strength level strong

The communication of confidential data protection strength level strong shall protect against the following attack types:

**eavesdropping:** An attacker secretly intercepts the communication between the SHGPVA and another entity or another part of the SHGPVA.

**person in the middle attack:** An attacker secretly alters the communication between the SHGPVA and another entity or another part of the SHGPVA to gain a trusted relationship with the involved communication partners without their knowledge.

**direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

**downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol.

---

## E.6 integrity protection strength

### E.6.1 INT-SWPCK Software package verification

#### E.6.1.1 General

The present document specifies software package verification mechanisms' strength, by certain protection measures. Those measures are constructed such that measures of higher strength typically have less attack vectors than lower strength measures.

## E.6.1.2 software package integrity verification strength level basic

Mechanisms for the software package integrity verification strength level basic shall:

- explicitly obtain the confirmation of an authorized entity that the integrity and authenticity of a software package has been verified by the entity, where the software package's source is determined by the entity; or
- explicitly obtain the confirmation of an authorized entity that the authenticity of a software package has been verified by the entity and use a hash or checksum provided by the entity for the software package to verify its integrity, where the software package's source is determined by the entity.

## E.6.1.3 software package integrity verification strength level normal

Mechanisms for the software package integrity verification strength level normal shall ensure that a software package has been obtained from a trusted source over a secure communication channel that meets INT.COM.Enhanced.

## E.6.1.4 software package integrity verification strength level enhanced

Mechanisms for the software package integrity verification strength level enhanced shall verify the authenticity and integrity of a software package using cryptographic digital signature verification.

# E.6.2 INT-COM Communication of integrity relevant data

## E.6.2.1 General

The present document specifies the strength of mechanisms to protect the integrity of communicated integrity relevant data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

## E.6.2.2 communication of integrity relevant data protection strength level basic

The communication of integrity relevant data protection strength level basic shall protect against the following attack types:

**accidental bit flip:** Accidental change of data by natural causes.

## E.6.2.3 communication of integrity relevant data protection strength level normal

The communication of integrity relevant data protection strength level normal shall protect against the following attack types:

**replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same interface to deceive it into performing unauthorized actions.

**accidental bit flip:** Accidental change of data by natural causes.

**direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

**downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol

## E.6.2.4 communication of integrity relevant data protection strength level enhanced

The communication of integrity relevant data protection strength level enhanced shall protect against the following attack types:

1925 **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same  
1926 interface to deceive it into performing unauthorized actions.

1927 **person in the middle attack:** An attacker secretly alters the communication between the SHGPVA and another entity  
1928 or another part of the SHGPVA to gain a trusted relationship with the involved communication partners without their  
1929 knowledge.

1930 **accidental bit flip:** Accidental change of data by natural causes.

1931 **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

1932 **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication  
1933 protocol

### 1934 E.6.2.5 communication of integrity relevant data protection strength level 1935 strong

1936 The communication of integrity relevant data protection strength level strong shall protect against the following attack  
1937 types:

1938 **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same  
1939 interface to deceive it into performing unauthorized actions.

1940 **person in the middle attack:** An attacker secretly alters the communication between the SHGPVA and another entity  
1941 or another part of the SHGPVA to gain a trusted relationship with the involved communication partners without their  
1942 knowledge.

1943 **accidental bit flip:** Accidental change of data by natural causes.

1944 **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

1945 **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication  
1946 protocol

1947

---

1948 **Annex F (informative):**  
1949 **Relationship between the present document and the**  
1950 **covered/not covered cybersecurity risks**

1951 Table [F.1](#) shows the threat scenarios considered, the mitigation measures related to them in the present document with  
1952 associated attack surface parameters, and the risk coverage.

1953

**Table F.1: Covered threats and remaining risks acceptance**

| No.  | Threat Actor   | Threat action | Asset                               | Threat details                         |                                                          | Requirement(s) for mitigation                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Relevant attack surface parameter | Risk coverage |
|------|----------------|---------------|-------------------------------------|----------------------------------------|----------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| [1]  | A threat actor | (mis)uses     | a function whose use can cause harm | on the SHGPVA                          |                                                          | <b>Prevention:</b><br>[ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.2</a><br>[AUTHZ-LP] <a href="#">5.1.3.3</a><br>[AUTHZ-R] <a href="#">5.1.3.4</a><br>[AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br><b>Information:</b><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[USERNOT-NOSECFUC] <a href="#">5.1.12.1</a><br><b>Restoration:</b><br>[SDC-FRM] <a href="#">5.1.2.4</a> | COM, IF and POE                   | C             |
| [2]  |                | tampers       | integrity relevant data             | permanently stored on the SHGPVA       |                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [3]  |                |               |                                     | volatile stored on the SHGPVA          |                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [4]  |                |               |                                     | communicated from or to the MP or RDPS |                                                          | <b>Prevention:</b><br>[INT-COM] <a href="#">5.1.4.2</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | COM, IF and POE                   | C             |
| [5]  |                | discloses     | confidential data                   | on the SHGPVA                          | unnecessarily processed                                  | <b>Prevention:</b><br>[DMIN-DJST] <a href="#">5.1.6.1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |                                   | C             |
| [6]  |                |               |                                     | permanently stored on the SHGPVA       | during storage                                           | <b>Prevention:</b><br>[CONF-SSM] <a href="#">5.1.5.1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | POE                               | C             |
| [7]  |                |               |                                     |                                        | after deletion                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [8]  |                |               |                                     | volatile stored on the SHGPVA          | during usage                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [9]  |                |               |                                     |                                        | after usage                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [10] |                |               |                                     | communicated from or to the MP or RDPS |                                                          | <b>Prevention:</b><br>[CONF-COM] <a href="#">5.1.5.2</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | COM, IF and POE                   | C             |
| [11] |                | tampers       | loss sensitive data                 | permanently stored on the SHGPVA       | during storage                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [12] |                |               | integrity relevant function         | on the SHGPVA                          |                                                          | <b>Prevention:</b><br>[INT-SWPCK] <a href="#">5.1.4.1</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                                   | N             |
| [13] |                |               | time sensitive function             |                                        | by interruption caused by a software update installation | <b>Prevention:</b><br>[AVAI-SUM-SCHEDULE] <a href="#">5.1.7.10</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                   | C             |

| No.  | Threat Actor | Threat action                                          | Asset                         | Threat details |                                                | Requirement(s) for mitigation                                                                                                                                                                                                                                                                                                                                                                                                                                 | Relevant attack surface parameter | Risk coverage |
|------|--------------|--------------------------------------------------------|-------------------------------|----------------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| [14] |              |                                                        |                               |                | by interruption of power supply                | <b>Information:</b><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br><b>Restoration:</b><br>[AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a>                                                                                                                                                                                                                                                                    |                                   | C             |
| [15] |              |                                                        |                               |                | by interruption of network connection          | <b>Prevention:</b><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br><b>Information:</b><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br><b>Restoration:</b><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a>                                                                                                                                                                                                 |                                   | C             |
| [16] |              |                                                        |                               |                | due to overloading of a resource or connection | <b>Prevention:</b><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a><br><b>Information:</b><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a>                                                                                                                                                                                                                     | IF                                | C             |
| [17] |              | exploits an implementation vulnerability to compromise | a product cybersecurity asset |                |                                                | <b>Prevention:</b><br>[LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[NKEV-MKAV] <a href="#">5.1.1.1</a><br><b>Information:</b><br>[NKEV-SUM-NOTIF] <a href="#">5.1.1.5</a><br>[SDC-SUM-NOTIF] <a href="#">5.1.2.3</a><br><b>Restoration:</b><br>[NKEV-SUM-SUPPORT] <a href="#">5.1.1.2</a><br>[NKEV-SUM-PROVIDE] <a href="#">5.1.1.3</a><br>[NKEV-SUM-AUTO] <a href="#">5.1.1.4</a><br>[SDC-SUM-AUTO] <a href="#">5.1.2.2</a> |                                   | C             |

1954

1955 • The columns *Threat Actor*, *Threat Action*, *Asset*, and *Threat Details* describe the threat scenario under  
 1956 consideration.

1957 • The column *Requirement(s) for mitigation* refers to the mitigations of the risks that arise from the threat  
 1958 scenario.

1959 • The *Relevant attack surface parameter* column describes which of the attack surface parameters make a  
 1960 difference in mitigation.

1961 • The *Risk coverage* column describes whether the risk associated with the threat scenario has been reduced to  
 1962 an acceptable residual risk (C) or not (N).

1963



---

1964 Annex G (informative):  
1965 Relationship between the present document and ETSI EN  
1966 303 645/ ETSI TS 103 701

1967 This informative annex is intended to provide a mapping between the present document and the content of ETSI  
1968 TC CYBER's existing work on CIoT devices (ETSI EN 303 645/ ETSI TS 103 701).

1969

1970

---

## History

| Version | Date          | Status                                                                                                                       |
|---------|---------------|------------------------------------------------------------------------------------------------------------------------------|
| V0.2.0  | February 2026 | Clean-up done by <i><a href="#">editHelp!</a></i><br>E-mail: <a href="mailto:edithelp@etsi.org">mailto:edithelp@etsi.org</a> |
|         |               |                                                                                                                              |
|         |               |                                                                                                                              |
|         |               |                                                                                                                              |
|         |               |                                                                                                                              |

1971